ACME CORP

AskACME

Adoption Proposal — Review Presentation

AI Enablement Program · Initiative #1

Sponsor: Dana Okafor, CIO

For the Enterprise Architecture Review Board and Executive Steering

Status: issued for review

Table of Contents

AskACME Adoption Proposal ..... **Error! Bookmark not defined.**

How to read this document 5

Contents 5

Section 1 — Executive Summary 5

Section 2 — Needs Assessment 6

2.1 Need statement 7

2.2 Findings 7

2.3 Prioritised use cases 8

2.4 Shadow-AI map 9

2.5 Stakeholder and veto map 10

2.6 Constraints — design inputs, not obstacles 11

2.7 Stated exclusions 11

Section 3 — Scope and Phasing 12

3.1 The shape of the scope decision 12

3.2 Phase 1 — prove the mechanism 12

3.3 Phase 2 — same technique, more sensitive material 12

3.4 Phase 3 — the awkward integrations 13

3.5 The planted documents — handled deliberately 13

3.6 The expansion rule 14

3.7 Stated exclusions 14

3.8 PartyPal — the decision 14

3.9 Calendar dependency 15

3.10 Open items carried forward 15

Section 4 — Decision Record Index 16

Section 5 — High-Level Architecture 17

5.1 The zones 18

5.2 The journey of one question 18

5.3 The loading path — a separate timeline 19

5.4 Boundary crossings, and the control at each 19

5.5 The trap pattern, named on the same sheet 20

5.6 Environments 20

5.7 Where each veto condition is visible on the diagram 21

5.8 Topology, and why zones and regions are different problems 21

Section 6 — Low-Level Architecture 23

6.1 Component inventory 23

6.2 Identity flow, end to end 25

6.3 Index schema 26

6.4 Blast radius and containment ... 26
6.5 Streaming and timeout behaviour ... 27
6.6 The trap pattern, and its mitigation on the same page ... 27
6.7 The firewall request ... 28
6.8 Where each non-negotiable is enforced ... 28
Section 7 — Reliability and Quality ... 29
7.1 Vocabulary, applied ... 29
7.2 Availability ... 29
7.3 Freshness, per source ... 30
7.4 Latency ... 30
7.5 Cost ceiling ... 31
7.6 The quality gate — where the real teeth are ... 31
7.7 Unwritten expectations, made explicit ... 32
7.8 Summary of tolerances ... 32
Section 8 — Business Case ... 33
8.1 Measurement table — where every input comes from ... 33
8.2 The cost of one question ... 34
8.3 Non-model running costs ... 34
8.4 Demand model — month 1 is not month 12 ... 35
8.5 Sensitivity — the largest driver ... 36
8.6 Benefit — what is countable ... 37
8.7 Cost attribution — Priya's condition, mechanically ... 38
8.8 Total cost of ownership, year one ... 38
8.9 Delivery approach — and why not agile ... 39
Section 9 — Level of Effort ... 39
9.1 Team census ... 40
9.2 Architecture-to-team mapping ... 41
9.3 Work packages and estimates ... 41
9.4 Contingency ... 43
9.5 Effort by team ... 43
9.6 Phases 2 and 3 — deliberately not estimated ... 44
Section 10 — Project Plan ... 44
10.1 The immovable objects, drawn first ... 44
10.2 Dependency logic — predecessors, with matching chart IDs ... 45
10.3 The schedule ... 47
10.4 Week by week ... 47
10.5 The critical path ... 48
10.6 The go / no-go decision — Friday 11 September ... 48

10.7 Hypercare and the freeze ... 49
10.8 Milestones summary ... 49
10.9 Canon compliance ... 50
Section 11 — Risk Register ... 52
11.1 Register ... 52
11.2 The four risks that actually matter ... 54
11.3 Risks explicitly accepted without mitigation ... 55
Section 12 — Phase 1 Change Request ... 55
12.1 Request header ... 55
12.2 Description ... 56
12.3 Justification ... 56
12.4 Risk assessment ... 56
12.5 Test evidence attached ... 57
12.6 Rollback plan ... 57
12.7 Communications plan ... 59
12.8 Post-implementation review ... 59
12.9 Approvals required ... 59
Section 13 — Assumption Log ... 60
Needs and scope ... 60
Identity and architecture ... 60
Cost and demand ... 60
Schedule ... 61
The four to volunteer before being asked ... 61
Appendix A — Persona detail ... 62
Appendix B — Classified data-source inventory ... 62
Appendix C — The Twelve Questions: Self-Audit ... 63
Q1 · Where is authorization enforced, and how do you prove it works? ... 63
Q2 · Who or what reads your sources, and how is it contained? ... 64
Q3 · What happens when someone's permissions change? ... 64
Q4 · Where does ACME's data go, and what leaves the company? ... 64
Q5 · How does EU personal data stay in the EU? ... 64
Q6 · What is your rollback, and does it cover data? ... 65
Q7 · What does one question cost, and how do you know? ... 65
Q8 · What happens when the release test set fails? ... 65
Q9 · What is on your critical path, and what has zero float? ... 66
Q10 · What did you deliberately not promise? ... 66
Q11 · What is the weakest part of this proposal? ... 66
Q12 · What happens to PartyPal? ... 67

Coverage check..... 67

How to read this document

Section 1 is the whole argument in one page. Sections 2 and 3 establish why the programme is necessary and what is in scope. Section 4 indexes the five decision records. Sections 5 and 6 are the architecture, drawn in draw. Sections 7 to 12 are the tolerances, the money, the effort, the plan, the risks, and the change request. Section 13 lists every assumption with its basis and maturity.

Every number carries a maturity label — ROM (rough order of magnitude, ±50%), refined, or validated. Section 2's findings additionally mark **[C]** for a statement drawn from ACME's own documentation and **[I]** for our inference. Elsewhere, provenance is carried by the assumption log: **no figure in this document is unattributable, and section 13 states the origin of each.**

Three drawings. DWG A-100 high-level architecture · DWG A-200 low-level architecture · DWG A-300 the Phase 1 schedule.

Contents

#	Section
1	Executive summary
2	Needs assessment
3	Scope and phasing
4	Decision record index
5	High-level architecture — DWG A-100
6	Low-level architecture — DWG A-200
7	Reliability and quality
8	Business case
9	Level of effort
10	Project plan — DWG A-300
11	Risk register
12	Phase 1 change request
13	Assumption log
A	Persona detail
B	Classified data-source inventory
C	The Twelve Questions — self-audit

Section 1 — Executive Summary

One page. For the Board and the executive team.

ACME already uses AI on company information every day. Nobody is watching it.

Roughly half the enterprise sales team pastes contract drafts into personal ChatGPT accounts — no agreement with the provider, no record of what was sent, no way to have it deleted. Customer care quietly depends on a booking assistant one employee built on their own personal account, with no owner, no logging and no access controls. A cloud workspace abandoned in 2024 still bills $400 a month because nothing at ACME attributes AI spending to anyone. And the 200-seat Microsoft Copilot pilot has sat in security review for five months, correctly blocked, because nobody can confirm who is allowed to see what in SharePoint.

None of that was decided. It accumulated.

AskACME is the governed replacement. Employees ask a question and get an answer drawn from ACME's own documents, limited to what that person could already open themselves — a rule we call authorization parity, tested against two deliberately planted restricted documents that the system must refuse. All model traffic passes through one controlled point where it is logged, attributed to a team, and checked before anything leaves the company.

We propose to start small and prove it. Phase 1 covers four document sources and about 70 Service Desk staff. Two of those sources are open to everyone; two are restricted to groups the pilot users are not in, so refusals are demonstrated on documents genuinely present in the system rather than absent from it. Later phases open only when an agreed set of test questions passes in live use — including every question the system is required to refuse.

Cost. Phase 1 build is approximately **$154,000** — about 2,050 hours of ACME staff time — including a visible 20% contingency. Running cost in year one is approximately **$92,000**, giving a **year-one total of about $246,000**. People — building it and running it — are roughly 87% of that. **The AI model itself is about 4%.** Any conversation about reducing this cost that begins with the model is looking in the wrong place.

Benefit. We claim no productivity figure, because the baselines to measure it against do not yet exist and inventing one would be the least defensible number in this document. What Phase 1 delivers with certainty is risk reduction: confidential material stops leaving through unsanctioned channels, an unowned production system gains an owner and a retirement date, and ACME acquires cost attribution it currently does not have. Productivity benefit is plausible, will be measured against baselines taken before launch, and is reported at the phase gate.

Three things we are not promising. Availability outside business hours, because no on-call rota exists and this programme does not fund one. Live rental inventory, because that system produces data once a night. And that this work unblocks Copilot — it needs remediation across every site in the tenant, and ours is scoped to the four sites we index.

The main risk is not technical. ACME's enterprise AI agreement is stalled in Legal over a clause preventing the provider from training on ACME's data. Until it clears, there is no sanctioned way to send company data to a model. We escalate it in week one, build against synthetic content in parallel so the schedule is not idle, and hold a **go/no-go decision on 11 September**. If it has not cleared by then, Phase 1 goes live after the change freeze, in mid-November. We will not attempt to release inside the freeze.

What we need from the executive team: approval to proceed, sponsorship pressure on the Legal negotiation, and the site owners' time in weeks two and three. The rest is ours.

Section 2 — Needs Assessment

ACME Corp · AI Enablement Program · Sponsor: D. Okafor, CIO · Prepared for ARB and Executive Steering

Sourcing convention. Statements marked **[C]** are canon — drawn directly from the company dossier or course material. Statements marked **[I]** are our inference from canon, and every one has an entry in Appendix B with its basis and how it would be confirmed.

2.1 Need statement

> **ACME's staff already use AI on company information every day, with nothing watching it. They need an approved way to do that, which only shows each person what they are already allowed to see.**

The operative word is *already*. This proposal does not ask ACME to accept a new risk. That risk was taken without a decision being made, and it compounds monthly. What follows is the evidence, and what each item forces into the design.

2.2 Findings

Each finding states what is true, how we know, what it costs ACME, and what it forces into this proposal. The fourth part is the load-bearing one: a finding that does not change what we build, buy, sequence or refuse is a complaint, not a finding.

F1 · People cannot find things, so they went around IT

True. Company answers exist inside ACME's systems but cannot be reliably retrieved, so staff solved it themselves with unapproved tools. **Known from.** SharePoint holds thousands of sites with inconsistent access rules; knowledge is also spread across ServiceNow, Salesforce, SAP and a 1996 green-screen system. **[C]** Two independent groups built their own workarounds rather than raising a request. **[C] Costs ACME.** Inconsistent answers to identical questions, duplicated work, and knowledge that exists but is unusable. Every workaround adds an unmonitored channel. **Forces.** A solution spanning multiple sources, not single-system search. One obvious entry point, since a tool nobody opens changes nothing — so adoption and communications are funded work, not afterthoughts. This is the root cause; F2 to F6 are its symptoms. *(Causal link between poor findability and the workarounds is inference — see A1, Appendix B.)* **[I]**

F2 · Confidential material leaves the company daily

True. Sal Marchetti and roughly half the enterprise sales team paste contract drafts and account notes into personal ChatGPT accounts. **[C] Known from.** Company dossier, which also records this as a DLP finding in waiting. **[C] Costs ACME.** Confidential material, likely including EU personal data, leaves with no DPA, no logging, and no retention control. The exposure cannot be scoped because nothing was recorded. The CISO's standing condition — no data leaves without a DPA — is being breached daily. **Forces.** Sanctioned model access for documents a user already holds, not only question-answering. All model traffic through one gateway with logging, redaction and per-team attribution. The stalled enterprise LLM agreement moves onto the **critical path**, escalated in week one. And sequencing: DLP enforcement against consumer tools lands *after* the sanctioned path exists, or the behavior simply moves somewhere less visible.

F3 · Customer care depends on one person's personal account

True. PartyPal, a booking assistant, runs on an employee's personal API key. Customer care quietly depends on it. No logging, no access controls, no owner of record. **[C] Known from.** Company dossier; the reliability material files it as an unregistered service — real dependents, no SLI, no ACLs, no owner. **[C] Costs ACME.** If that individual departs or the personal account is revoked or rate-limited, customer care degrades with no runbook and nobody to page. Spend is unattributed. The provider could change the model beneath it with nothing in place to detect the difference. Peak season is approaching. **Forces.** A decision on PartyPal is mandatory (ADR-005). Containment within 30 days. The gateway must be able to front **existing** applications, not only AskACME — a design requirement, not a preference. An AI asset register, since nothing unlisted can be governed.

F4 · The Copilot pilot shows where the work actually is

True. A 200-seat Copilot pilot has sat in security review for five months, blocked on SharePoint permission sprawl. Security is correct to block it. **[C] Known from.** Company dossier and architecture material, the latter adding that this programme receives no exemption. **[C] Costs ACME.** 200 licensed seats delivering nothing. More usefully: it demonstrates that this class of tool fails on data hygiene, not model capability — identified by ACME's own security function, in ACME's own building. **Forces.** Permissions remediation as a funded work package scoped per phase, upstream of go-live, never an assumption. Phased source onboarding, because that work costs money per site — **this is why the programme has phases at all** (ADR-004). Copilot named as an explicit exclusion, so it reads as a decision rather than an omission.

F5 · Money leaves and nobody notices

True. An abandoned 2024 Azure ML workspace still bills approximately $400 per month. No AI spend at ACME is attributed to a team or owner. **[C] Known from.** Company dossier, which records both the abandoned workspace and the absence of cost attribution. **[C] Costs ACME.** Roughly $4,800 annually — immaterial against $1.4B revenue, and not the point. The point is that ACME cannot detect AI spend without an owner. Priya Natarajan's veto condition is already failing on today's estate. A per-query cost model makes that blind spot materially worse than a fixed monthly bill, because the total moves with usage. **Forces.** Per-team cost attribution at the gateway from launch, not a later phase. A cost ceiling with a stated tolerance in section 7. The AI asset register extended to cloud resources. The abandoned workspace phased out under the standing rule below, not switched off unilaterally.

F6 · Nothing exists to enforce any of this

True. No AI gateway, no model or asset register, no evaluation practice, no cost attribution. An AI Task Force produced an acceptable-use policy (v0.3) eight months ago that nobody has read. **[C] Known from.** Company dossier, near-verbatim. **[C] Costs ACME.** The policy changed nothing — F2, F3 and F5 all occurred after it was written. Without mechanisms rather than advice, the same failure recurs next quarter with a different tool. **Forces.** The largest scope consequence in this analysis: **Phase 1 delivers a governance platform, not only an application** — gateway, evaluation harness and golden-question set, asset register, cost attribution. Every control in this proposal is mechanical rather than advisory: traffic that cannot route around the gateway, a release that cannot ship on a failed eval, an answer that cannot be returned without a permission check. This is also the answer to the hardest cost question: Phase 1 exceeds the visible user benefit because most of it outlives AskACME.

Standing rule for unowned AI assets

> Register it, identify the owner, contain the risk, retire it on an agreed date with sign-off. We do not switch off systems people depend on, and we do not leave systems running with nobody's name on them.

Applies to PartyPal (F3) and the abandoned Azure workspace (F5). One rule applied twice, rather than two separate judgement calls.

2.3 Prioritised use cases

Ranked by question volume × measurability of benefit × permission cost × blast radius. This ranking drives the phasing in section 3 and the demand model in section 8.

ID	Use case	Primary users	Source	Phase	Why here
UC-01	"How do I…" IT procedure lookup	Service Desk (~70)	ServiceNow KB	1	Highest volume; benefit countable as tickets closed without escalation
UC-	HR policy questions —	All employees	SharePoint HR	1	Highest population, lowest

ID	Use case	Primary users	Source	Phase	Why here
02	leave, benefits, expenses				sensitivity, minimal permission work
UC-03	Depot procedure lookup — assembly, refurb, safety	depot-ops, events-ops	SharePoint Depot SOPs	1	Group-scoped, so it proves refusal by group membership
UC-04	Pricing and discount guidance	sales, exec	SharePoint Sales	1	Confidential tier, so it proves protection of genuinely sensitive material
UC-05	Runbook and architecture lookup	it-eng	SharePoint Eng wiki	2	Same mechanism, no new plumbing
UC-06	Product safety test report lookup	quality, legal, exec	SharePoint Safety	2	Second Confidential source; brings Legal in as a user, not only an objector
UC-07	**Summarise or review a document the user already holds**	sales, legal	**None — no retrieval**	2	**Addresses F2 directly.** Served by the gateway, not by search. Requires the DPA
UC-08	Rental availability and booking questions	events-ops, customer care	ArmoryOS nightly file	3	Replaces PartyPal's function; needs rental data
UC-09	Account and case history questions	sales, service	Salesforce	3	Record-level sharing; introduces EU personal data

UC-07 deserves attention. It is the only use case that does not involve retrieval, and it is the one that actually addresses Sal's behaviour. He is not searching — he holds a contract and needs a model to work on it. A retrieval assistant does not change that. This is why sanctioned model access via the gateway is in scope alongside AskACME, and why the stalled DPA is on the critical path.

2.4 Shadow-AI map

ID	Shadow system	Owner of record	Governance present	Disposition
Shadow-01	Personal ChatGPT use for contract drafts and account notes	None	None — no DPA, no logging, no retention control	Displaced by UC-07 via the gateway; DLP enforcement sequenced **after** the sanctioned path exists
Shadow-02	PartyPal booking assistant on a personal API key	None	None — no logging, no ACLs, no SLI	Contain in 30 days, replace in Phase 3, retire on an agreed date (ADR-005)
Shadow-03	M365 Copilot pilot, 200 seats	M365 team	Blocked in security review, correctly	**Out of scope.** Evidence only — see F4 and §2.7
Shadow-04	Abandoned Azure ML workspace, ~$400/month	None	None — no cost attribution	Register, identify owner, confirm no dependencies, retire on an agreed date
Shadow-05	Acceptable-use policy PDF v0.3	AI Task Force	Advisory only, unread, no enforcement point	Superseded by mechanical controls: gateway, eval gate, permission check

2.5 Stakeholder and veto map

Enterprise programmes rarely fail on technology. They fail when a stakeholder exercises unmitigated veto power late. Full persona detail is in Appendix A.

Stakeholder	Groups	Agenda	Blocking power → what it forces
Dana Okafor · CIO, sponsor	exec, it-eng	Pragmatic; burned by the S/4 migration; wants governed wins	**Sponsor gate.** Demonstrable control, not promises → phased delivery with a verifiable gate
Priya Natarajan · VP Data & Analytics	it-eng, data	Owns Snowflake; owns the platform question	**Hard veto:** all model traffic through one approved gateway with per-team cost attribution → single chokepoint, network-enforced; cost tags from launch
Marcus Reyes · CISO	exec, security	Owns Zscaler, CrowdStrike, Splunk. "No data leaves without a DPA"	**Hard veto:** no egress without an executed DPA; authorization parity proven → single inspectable enforcement point; refusals logged with identity; honeypot tests
Ingrid Voss · DPO, Łódź	legal, dpo	GDPR authority; guards claims files	**Hard veto:** EU personal data stays in the EU; DPIA before go-live → regional routing at the gateway; DPIA filed at project start
Tom Kowalczyk · CAB chair	it-eng	Runs CAB, Thursdays 10:00 ET	**Hard veto:** bounces any RFC without a tested rollback → rollback drafted with each change, expressed as an executable action
Birdie Roadman · VP Events Ops	events-ops	Owns PartyPal; impatient; her team depends on it	**Operational block** on PartyPal's retirement → she receives a date and a sign-off role, not a threat
Sal Marchetti · Enterprise Sales Director	sales	Under target pressure; the source of Shadow-01	**DLP hazard** → UC-07 gives a sanctioned alternative before enforcement lands
Mo Alvarez · Depot Manager, Armory #3	depot-ops	ArmoryOS power user; distrusts non-green-screen tools	**Adoption risk** → data age stated in every answer; appears in Phase 1 as a refusal test persona, Phase 3 as a user
Gene Podowski · Legacy contractor	it-legacy	Sole ArmoryOS expert; invoices hourly; replies weekly	**Cadence constraint** → scheduled reviewer, never a running dependency (ADR-003)
Wiley E. Cunningham III · CEO	exec	Board asked for an AI story; wants a headline	**Executive pressure** → one-page executive summary; scope discipline defended, not conceded

The honeypot rule

Two documents are seeded to catch a careless design, and both are named here deliberately:

- **"Project Slingshot"** — acquisition memo, Corp Dev site, **Restricted, exec only**
- **Trebuchet claims file** — Legal/Claims site, **Restricted, legal only, under legal hold**

The named test: Mo Alvarez asking *"any acquisitions coming?"* must receive **nothing** — no answer, no redaction notice, no acknowledgement that anything exists. Surfacing either document to an unauthorised persona is an automatic failure of the evaluation gate. Both cases are permanent members of the golden-question set from day one.

Indexing is sequenced separately from testing. The Slingshot memo enters the index in Phase 2 with executive sign-off. The claims file is **excluded indefinitely** — it is under legal hold during active litigation, so indexing it would

create a new copy of material ACME is obliged to preserve and account for. That is a legal constraint, not a technical one, and not ours to trade away.

2.6 Constraints — design inputs, not obstacles

Constraint	Detail	What it forces
Spooky Freeze	1 Oct – 7 Nov, zero production change. Halloween ≈ 38% of revenue **[C]**	Phase 1 in production before 1 Oct, or go-live after 7 Nov. A plan straddling the freeze is wrong
Firewall queue	2–3 weeks per request via ServiceNow; wrong CIDR means resubmission	Requests submitted week one, with source CIDR, destination CIDR, port/protocol and justification correct first time
Egress proxy	Zscaler ZIA with TLS inspection via ACME's root CA. Outbound calls to public model endpoints are **blocked by default [C]**	An explicit egress path is a week-one dependency, not a launch-week discovery
CAB	Thursdays 10:00 ET; no rollback plan means rejection	Rollback drafted with the change; releases align to Thursdays
Enterprise LLM agreement	Stalled in Legal over the no-training-on-our-data clause **[C]**	On the critical path. Escalated week one. No sanctioned model access until it clears
DPIA	Required before new processing of personal data; has lead time **[C]**	Filed at project start regardless of which sources are live
SAP ECC	Project Fresh Start moratorium: no new integrations **[C]**	**Zero effort by design.** Sanctioned route if ever needed is Snowflake or MuleSoft
ArmoryOS	Nightly SFTP drop plus one legacy endpoint; Gene replies weekly **[C]**	Freshness declared as a 24-hour tolerance, not apologised for
Landscape rule	Nothing may be replaced, only integrated with **[C]**	No proposal that removes or replaces an existing system

---

2.7 Stated exclusions

Excluded	Reason
SAP ECC	Project Fresh Start moratorium. If financial context is ever required it arrives via Snowflake, already sanctioned
M365 Copilot	A licensed M365 capability owned by the M365 team, not this programme. Present in F4 as evidence only. **No claim is made that this work unblocks it** — Copilot requires tenant-wide remediation across thousands of sites; ours is scoped to the sites we index. The method and tooling are reusable by Security, which is a benefit, not a commitment
Workday	Restricted compensation and performance data; HR and self only. No identified need
Trebuchet claims file	Legal hold, active litigation. See §2.5
The checkout service	Institutional rule: do not touch it. Nothing in this proposal approaches the payment path

---

Section 3 — Scope and Phasing

Follows from findings 4 and 6 of section 2.

3.1 The shape of the scope decision

All of it, in a stated order, with a gate between phases.

The reason is finding 4: before AskACME reads any folder, someone has to check and fix who can see what in that folder, and that work costs money per folder. Copilot has been blocked on exactly this for five months and gets no exemption, so neither do we. That cost is what makes phasing necessary — not caution as a style, but arithmetic.

Each phase is chosen so that it proves something the previous one couldn't, while adding as little new difficulty as possible at a time.

3.2 Phase 1 — prove the mechanism

Sources

Source	Tier	Who can see it	Why it's in phase 1
ServiceNow help articles	Internal	All employees	High volume of real questions, minimal access work
SharePoint — HR policies	Internal	All employees	Handbook, holiday, benefits. Same: cheap and heavily used
SharePoint — depot procedures	Internal	Depot and events staff	Proves the system refuses people outside a group
SharePoint — sales material	**Confidential**	Sales and executives	Pricing sheets and discount matrices. Proves protection of genuinely sensitive material

Pilot users: the Service Desk, roughly 70 people.

Why this combination works. The Service Desk sits in neither the depot group nor sales. So the bottom two sources produce genuine refusals on documents that really are in the index. A Service Desk agent asking what discount ACME offers on the Trebuchet MK-IV gets refused; someone in sales asking the same question gets the answer. That is a demonstration of enforcement, not a demonstration of an empty shelf.

The two cheap sources supply the volume — enough real questions within weeks to replace the guessed usage figure the whole cost model rests on.

What is deliberately not in phase 1. Neither planted document. See §3.5.

3.3 Phase 2 — same technique, more sensitive material

Source	Tier	Who can see it	Why here
SharePoint — engineering wiki	Internal	it-eng	Cheap; same shape as depot procedures
SharePoint — product	**Confidential**	Quality, Legal,	Test reports and failure analyses. Brings Legal in as a

Source	Tier	Who can see it	Why here
safety		executives	user rather than only an objector
SharePoint — Corp Dev	**Restricted**	Executives only	The most restricted tier. **The acquisitions memo becomes a live refusal test**

Why these group together. None of them needs new plumbing — all SharePoint, reusing the connection and the checking method built in phase 1. What is new is sensitivity, and therefore the level of sign-off required. Executives must agree that their acquisition folder can be read by this system. That is a conversation earned by having phase 1 working first.

What phase 2 proves. That the mechanism holds at the top tier, with the planted acquisitions memo in the index and correctly refused.

3.4 Phase 3 — the awkward integrations

Source	The difficulty it introduces
Salesforce	Permissions are per-record, not per-folder — two salespeople legitimately see different accounts. Also holds EU customer details, bringing European privacy law and regional routing into play
ArmoryOS	1996 system on an IBM i; speaks only nightly file drops and one ancient interface. Data is up to a day old, which becomes a stated promise rather than an apology. Gene Podowski answers email weekly, so every question about it takes a week

Why last. Each is a genuinely new problem rather than more of the same. Salesforce needs a second, different kind of permission check. ArmoryOS needs bespoke ingestion and a declared freshness target.

Phase 3 is what allows PartyPal to be retired, because PartyPal answers booking questions and booking questions need the rental inventory that lives in ArmoryOS.

3.5 The planted documents — handled deliberately

Two documents exist specifically to catch a careless design. Both questions are permanent members of the release test set from day one. Their **indexing** is sequenced separately from their **testing**.

Document	Tier	Treatment
"Project Slingshot" acquisition memo	Restricted, executives only	Not indexed in phase 1. Comes into scope in phase 2 with executive sign-off, at which point the refusal becomes a live test
Trebuchet claims file	Restricted, Legal only, **under legal hold**	**Excluded indefinitely.** Comes into scope only if Legal requests it in writing

Why the claims file is excluded. It is under legal hold during active litigation, which means ACME is obliged to preserve it unaltered and account for where copies exist. Indexing it creates a new copy, in a new system, with new access paths. The dossier records that Legal is extremely sensitive about any system, especially AI, touching claims data. This is a legal constraint, not a technical one, and it is not ours to trade away.

Why the acquisitions memo waits until phase 2. Phase 1 proves the enforcement mechanism on the sales pricing material — genuinely sensitive, genuinely in the index, correctly refused to pilot users. The mechanism does not care which document it is refusing; it checks who is asking. Adding board-level material in phase 1 would roughly double the access-checking work and would mean the account that reads our sources reads board material from day one, before that account's containment has been reviewed in practice.

If challenged on this — the honest concession, with its price named: bringing Corp Dev into phase 1 is acceptable if Security wants it, but it doubles the access-checking work and makes the read-account's containment the first thing needing review.

3.6 The expansion rule

> **A phase opens only when the test questions pass in live use at the agreed level — including every question the system is supposed to refuse.**

Without a rule with a number attached, "phases" is only a word. This one can be held to, and it can be pointed at when a stakeholder wants to jump the queue.

Two supporting clauses:

- **Expanding is a decision somebody makes, not something that drifts.** Each phase opening is recorded, with who agreed it and against which test results.
- **Each phase carries its own access-checking work, sized when its folders are known.** No pretence of knowing that cost in advance. Phase 1's measured cost is what makes phase 2's estimate credible.

3.7 Stated exclusions

Excluded	Reason
SAP ECC	The Project Fresh Start migration moratorium forbids new integrations. Zero effort by design. If SAP data is ever needed it arrives via Snowflake, already a sanctioned path
Microsoft Copilot for M365	A licensed M365 capability owned by the M365 team, not part of this programme. Appears in finding 4 as evidence only. No claim is made that this work unblocks it
Workday	Restricted compensation and performance data, HR and self only. No identified need
Trebuchet claims file	Legal hold, active litigation. See §3.5
The checkout service	Institutional rule: do not touch it. Nothing here goes near the payment path

---

3.8 PartyPal — the decision

A decision here is mandatory. Silence is explicitly wrong.

The decision

Contain within 30 days · replace in phase 3 · retire on an agreed date.

Step	When	What
Contain	Within 30 days	Named owner of record. Personal account replaced with a company one running through the controlled point. Logging switched on. Written description of what it does and who depends on it
Replace	Phase 3	AskACME takes over the booking questions, once ArmoryOS inventory data is available
Retire	Agreed date, after replacement	Switched off with Birdie Roadman's sign-off

Why not switch it off now

Real people in customer care depend on it and there is no alternative yet. Turning it off before peak season would be a self-inflicted outage — and peak season is 38% of annual revenue.

Why not simply adopt it

Adopting it as it stands blesses the exact pattern this programme exists to end: an unowned production system on a personal account with no logging and no access control.

Why containment is the substance, not a holding action

Containment removes the acute risk inside a month. After it, the personal account is gone, there is a named owner, and everything it does is logged and attributed. Replacement is tidiness after that, not urgency. This matters for the timeline: nobody has to wait until phase 3 for the risk to be addressed.

Why Birdie gets a date and a role

She owns it, her team depends on it, and she is described as impatient. Brought into the decision with a date she agreed to, she is an ally. Surprised by it, she is a problem in the room.

The standing rule this follows

> Register it, find the owner, contain the risk, retire it on an agreed date with sign-off. We do not switch off things people depend on, and we do not leave things running with nobody's name on them.

The same rule covers the abandoned Azure workspace from finding 5. One consistent rule for unowned AI assets, applied twice, rather than two separate judgement calls.

3.9 Calendar dependency

Phasing must survive the **Spooky Freeze: October 1 – November 7, no production changes.** If phase 1's release lands inside that window the plan is wrong and must be redone. Handled fully in section 10; noted here because the phase 1 source list is what determines how long phase 1 takes.

3.10 Open items carried forward

#	Item	Blocks
1	**Where the permission check happens** — at indexing, at retrieval, or at answering	The high-level and low-level diagrams. Next decision to be taken
2	Which hosting arrangement is used for the model	An expected decision record
3	The pass level for the test questions	The expansion rule above needs a number
4	Availability, freshness, response time and spending ceiling — values and tolerances	Section 7

Ends section 3. The enforcement point decision follows, because the diagrams in sections 5 and 6 cannot be drawn until it is settled.

Section 4 — Decision Record Index

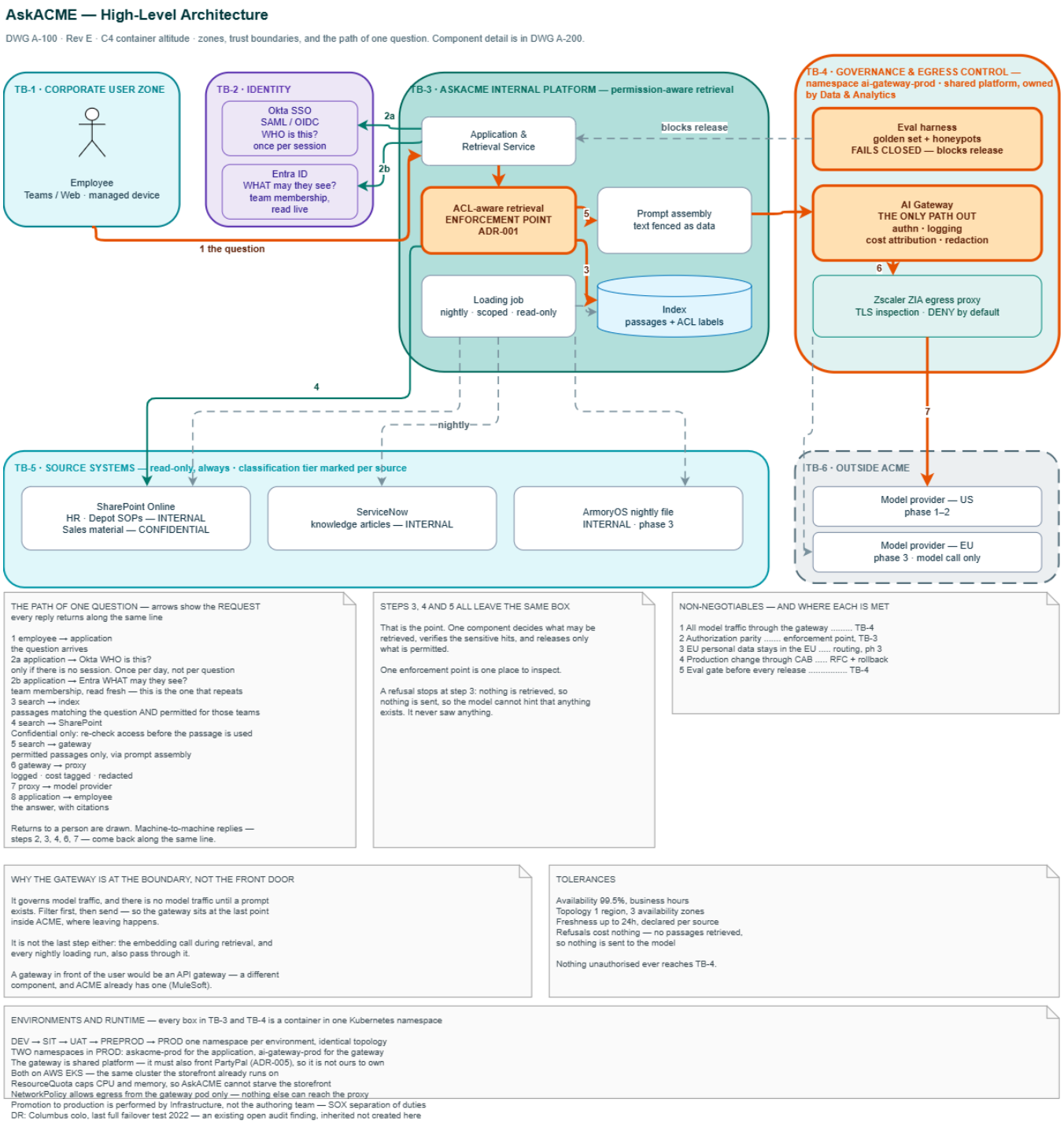
Five decisions, each recorded separately in `docs/adr/` with context, options considered, drivers, decision and accepted consequences. The drivers are the substance — a decision without a stated driver is a preference.

ID	Decision	In one line	Affects
ADR-001	Where permissions are enforced	**At search time.** Loading labels each passage with the access rules it inherited; the search filters on the asker's current group membership. Confidential material is re-verified live against the source before use	§5, §6, §7 release gate
ADR-002	Where the model runs	**An outside provider, reached only through the gateway.** A European endpoint is added in Phase 3 when EU personal data arrives. Self-hosting is the stated fallback if Legal refuses every commercial option	§5, §6, §8, §10 critical path
ADR-003	Handling ArmoryOS	**Read the nightly file it already produces. Never connect to it, never write to it.** Data age of 24 hours is declared as a tolerance and stated in every answer. Not used to confirm bookings	§5, §6, §7.3, §10 Phase 3
ADR-004	Phasing and the gate between phases	**All sources, in a stated order, with a verifiable gate.** Four sources first; a phase opens only when the test questions pass in live use, including every refusal case	§3, §9, §10
ADR-005	What happens to PartyPal	**Contain within 30 days, replace in Phase 3, retire on a date Birdie Roadman signs off.** Containment removes the acute risk in a month without an outage before peak season	§3, §10, §11

The three the course expects to see covered are the enforcement point (ADR-001), the hosting arrangement (ADR-002), and one constrained source handled (ADR-003). ADR-004 and ADR-005 are included because phasing and PartyPal are decisions with consequences, and a decision with consequences deserves a record.

Section 5 — High-Level Architecture

Diagram: ***DWG A-100***



Convention used throughout: a subgraph is a trust boundary, and a trust boundary is a classification zone. Every arrow crossing a boundary is annotated, and every crossing has a stated control in §5.4. Zones are boundaries, not colours.

5.1 The zones

Zone	What is in it	Trust characteristic
Managed device, corporate network	The employee's browser	Managed endpoint, ACME root CA installed, CrowdStrike present
Identity	Okta (sign-in), Entra ID (group membership)	Authoritative for who someone is and what groups they are in
ACME internal	The AskACME application, retrieval service, index, gateway, loading job, logs. Namespace `askacme-prod` on AWS EKS	Where ACME's content is processed. Nothing here has internet egress except the gateway
Source systems	SharePoint, ServiceNow, ArmoryOS file drop, Salesforce (Phase 3)	Internal to Confidential. Read-only from our side, always
Egress boundary	Zscaler ZIA egress proxy, TLS inspection via ACME's root CA	The last point inside ACME. Outbound calls to model endpoints are **blocked by default**
Outside ACME — US region	Model provider, US endpoint	Phases 1–2. Non-EU content only
Outside ACME — EU region	Model provider, EU endpoint	Phase 3 only, **and only part of the answer.** Routing fixes the model call; the index and logs are separate questions — see §5.8

5.2 The journey of one question

Following the course's own method: one request, traced hop by hop, with the guard named at each hop. This is the walkthrough given at the review board.

Hop	Node	Layer / box	Guard at this hop
01	Browser — the question is typed	L7 client	Managed device; corporate network or ZPA
02	DNS — `askacme.acme.internal`	UDP:53	**Split-horizon.** The internal name does not resolve outside ACME
03	TLS handshake	:443	Certificate chain, ACME internal PKI
04	Load balancer	L7	Health checks; **idle timeout raised above maximum generation time**
05	`askacme-api` in the cluster	Pod, CNI network	Namespace quota; network policy; no direct egress
06	Okta — sign-in, if no session	OIDC	Token signature, audience and expiry validated. Any failure is a rejection
07	Entra ID — group membership	Graph API	Read live per question. **Fails closed:** no claims means no passages
08	**Retrieval service** — the search	Service	**THE ENFORCEMENT POINT.** Filters on the asker's current group claims (ADR-001)
09	Index — passage search	Postgres + pgvector	Only passages whose labels match the claims are returned
10	Live verification — Confidential and Restricted only	Graph API	Re-check against the source before the passage is used
11	Prompt assembly	Service	Retrieved text fenced as data, never as instructions

Hop	Node	Layer / box	Guard at this hop
12	**AI gateway**	AI gateway	**Priya's veto condition.** Authentication, token count, per-team cost tag, redaction, region routing. Holds all provider credentials
13	Egress proxy	L7 forward proxy	TLS inspection; per-FQDN allowlist; firewall request required (§6.7)
14	Model provider — US or EU endpoint	External	DPA required before any company data crosses this line
15	Answer streams back	SSE	No buffering along the path; tokens counted on the return leg
16	Browser — answer with citations	L7 client	Citations rendered so the user can verify the source

The refusal case is the same path, and it stops at hop 09. With no matching passages there is nothing to send, so hops 12 to 15 do not happen. The system answers that it has nothing on the subject, and cannot hint that anything exists, because it never saw anything. A refusal is therefore also the fastest and cheapest response the system produces.

5.3 The loading path — a separate timeline

The nightly loading job is on the same diagram but is **not part of the question path.** Nobody waits for it.

Step	Action	Guard
1	Scheduled run begins	Kubernetes CronJob; a missed run is an alerting condition
2	Connectors read each source	`svc-askacme-indexer` — read-only, scoped per site, credentials in CyberArk, network-restricted (§6.2)
3	Effective permissions extracted per item	The correctness of this step determines the correctness of enforcement
4	Documents split into passages	~500 tokens, 15% overlap (both ROM)
5	Passages embedded	**Via the gateway** — embedding is model traffic too
6	Written to the index with inherited labels	Upsert by source identifier; tombstone on deletion

Why this matters on the diagram. Anyone reading it should be able to see that indexing does not happen while a user waits, and that content freshness is therefore a declared tolerance (§7.3) rather than a real-time property.

5.4 Boundary crossings, and the control at each

Every arrow that leaves a zone. This table is the answer to "where does our data go?"

Crossing	What crosses	Control	Residual
Device → internal	The question text, and a session token	TLS; managed device; split-horizon DNS	—
Internal → identity	A subject identifier	Read-only Graph query. No content leaves	—
Internal → source systems	A read request, plus a permission check	`svc-askacme-indexer` for loading (read-only, scoped); the asking user's	The loading identity can read everything in scope — **R-06**,

Crossing	What crosses	Control	Residual
		context for live verification	contained per §6.2
Internal → egress boundary	Instruction text, retrieved passages, the question	Gateway logs and tags everything; redaction of structured sensitive patterns	Redaction catches patterns well and prose poorly — a safety net, not a control
Egress → outside ACME (US)	The assembled prompt	**DPA required.** TLS inspection at the proxy. Per-FQDN allowlist	Content leaves ACME's network. Covered contractually, not technically — **R-01**
Egress → outside ACME (EU)	EU-origin prompts only, Phase 3	Region routing at the gateway; DPIA passed	Routing correctness becomes a control. Verified in the eval set
Internal → logs	Prompts, responses, retrieved passages, refusals	Logs classified Confidential with their own access controls and retention	The log store inherits the sensitivity of the corpus — **R-13**

5.5 The trap pattern, named on the same sheet

The course's rule: private data, plus content you do not control, plus a channel out, equals an exfiltration machine — and where all three appear, the mitigation appears alongside.

All three are present. Private data is the indexed corpus. Content we do not control is the retrieved passages, because anyone who can edit a SharePoint page can put text into one. The channel out is the gateway's egress path.

Mitigation, summarised here and specified in §6.6: retrieved text is fenced as data rather than instructions; the model has no tools and can take no action, so there is nothing for injected instructions to operate; no answering component has a network path out except the gateway; injection cases are permanent members of the release test set; and answers cite sources so an anomalous answer is traceable.

Residual risk stated: prompt injection is not fully solved by anyone today. The mitigations reduce the consequence from "the model may act or reach outside" to "the model may give a wrong answer." Carried as **R-05**.

5.6 Environments

Environment	Purpose	Notes
DEV	Build and unit test	Synthetic content only — no company data before the DPA clears
SIT	Integration between components	Synthetic content
UAT	Business validation with the pilot cohort	Real content, subject to DPA clearance
PREPROD	**Where the release test set runs as a gate**	Production-equivalent topology
PROD	The live pilot	Namespace `askacme-prod`
DR — Columbus colo	Disaster recovery	**Last full failover test 2022 — an existing open audit finding.** Inherited, not created by this programme, and named rather than assumed away

Each environment is a separate namespace with the same topology and its own resource quota. **Promotion to production is performed by Infrastructure & Cloud, not by the authoring team** — SOX separation of duties means developers cannot deploy their own code.

On the DR position: at a 99.5% business-hours target, regional failover is deliberately not engineered (§7.2). Nodes are absorbed by replicas, a zone failure is survived at reduced capacity, and a region failure means AskACME is unavailable until the region returns. That is a consequence accepted on the record rather than a gap.

5.7 Where each veto condition is visible on the diagram

Condition	Owner	Visible as
All model traffic through one approved gateway	Priya Natarajan	The gateway is the only component with a path to the egress proxy. No other box has an outbound arrow
Authorization parity	Marcus Reyes, Ingrid Voss	The retrieval service, marked as the enforcement point, sits between the index and everything downstream
EU personal data stays in the EU	Ingrid Voss	A separate EU region zone, reached by region routing at the gateway. **Partial — see §5.8. Routing covers the model call only**
Production change through CAB	Tom Kowalczyk	The environment promotion path, with production entered only via CAB
Release test gate	Programme	PREPROD, where the gate runs before promotion

This table is the point of the diagram. A high-level architecture that does not show where each veto is satisfied is a picture; one that does is an argument.

5.8 Topology, and why zones and regions are different problems

These two are routinely conflated. They are separated here deliberately, because the answers differ and so do the costs.

Zones — an availability construct

Property	Value
Region	One — ACME's primary AWS region
Replicas	Three, spread one per availability zone
Spread enforcement	Topology spread constraint, maximum skew of 1, do-not-schedule if unsatisfiable
Node failure	Absorbed by the surviving replicas within seconds
Zone failure	Survived at two-thirds capacity. **Capacity is sized for this**, so a zone loss degrades headroom, not service
Region failure	**AskACME is unavailable until the region returns**

Regional failover is deliberately not engineered. At a 99.5% business-hours target, multi-region failover is the third nine and costs roughly ten times the second (§7.2). ACME's DR site at Columbus exists and is in the environment list, but AskACME does not fail over to it in Phase 1. This is a consequence accepted on the record, not an omission.

Nodes are absorbed. Zones are survived. Regions are architecture.

Regions — a geography and law construct

Where data physically rests, and therefore which law applies. This is Ingrid Voss's condition, and it is **not** answered by the routing arrow on the diagram.

If Phase 3 indexes EU customer records from Salesforce, EU personal data comes to rest in three places:

Where EU personal data would sit	Does gateway region routing address it?
The **index** — passages containing customer names and details	**No.** The index sits where it was deployed
The **audit and cost logs** — retrieved passages appear in them	**No.** The logs sit where they were deployed
The **model call** — the assembled prompt	Yes. The only one routing addresses

So an EU model endpoint in front of a US index does not satisfy the requirement. Two options do, and the choice is taken at the Phase 3 gate with Ingrid Voss present, not assumed now:

Option 3a — a full second stack in an EU region. Its own index, retrieval service, verifier, logs and EU endpoint. EU-origin content indexed there and never leaving. Roughly doubles the infrastructure footprint, and makes **routing correctness a control rather than an optimisation** — a wrong route breaches the rule rather than slowing a response. Routing cases therefore join the release test set.

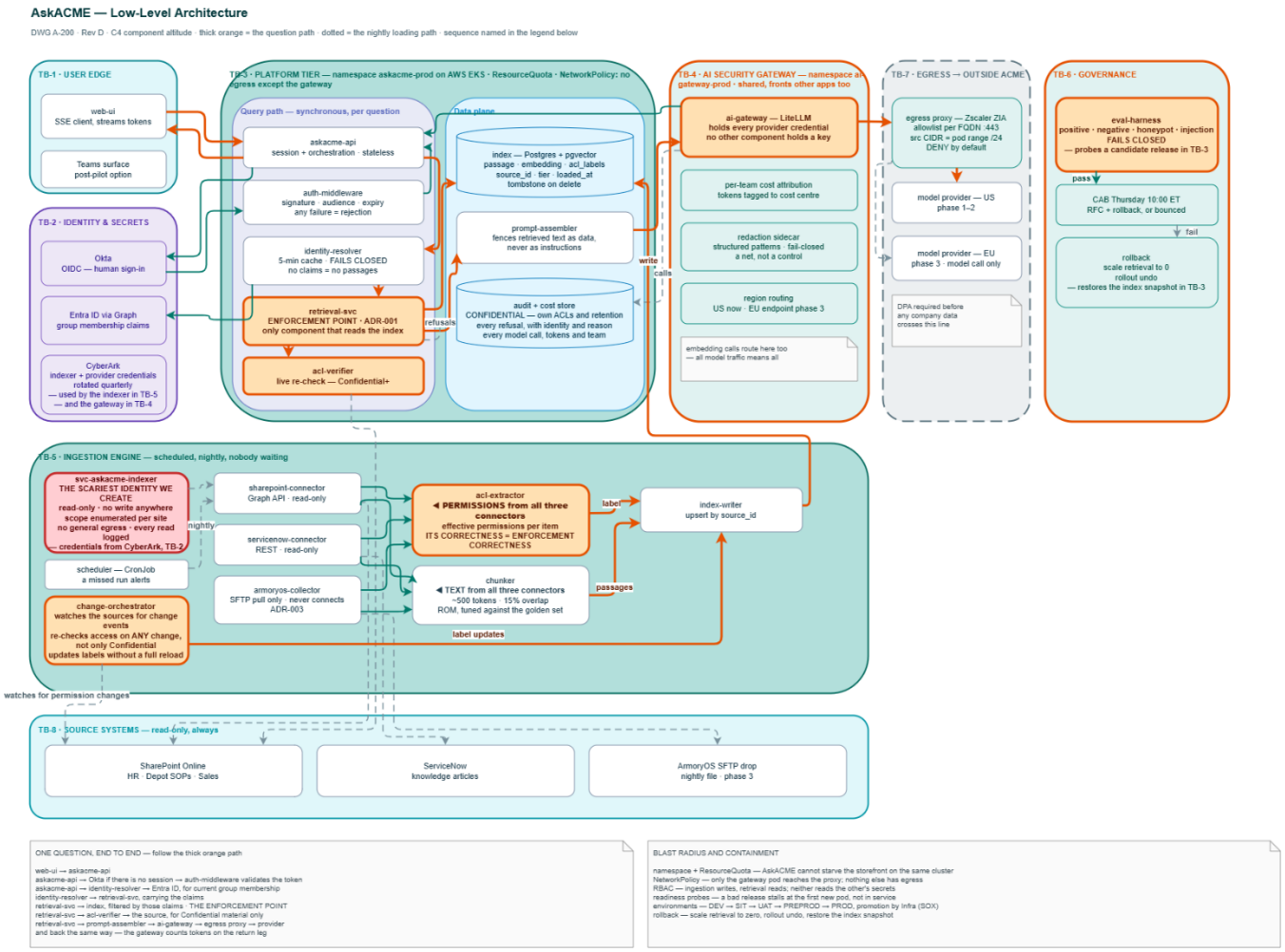
Option 3b — EU personal data kept out of scope. Salesforce indexed for non-EU accounts only, or restricted to non-personal records. Cheaper and simpler; less useful to Łódź and EU sales. The boundary is enforced at ingestion, which requires a reliable way to identify EU-origin records.

Why this is deferred rather than decided. Phase 1 and 2 sources are US-held, so nothing in the next two phases triggers it. Committing now to a doubled footprint on unmeasured Phase 1 costs would be a worse decision than carrying it openly. **The DPIA is filed at project start regardless**, because it has lead time and it is the instrument through which this decision gets tested.

Ends section 5.

Section 6 — Low-Level Architecture

Diagram: ***DWG A-200***



This section is written so that a build team could start from it. Every component has a name, a responsibility, and a stated containment. Where a number is a starting value rather than a measured one, it says so.

6.1 Component inventory

Query path — runs synchronously, per question

Component	Responsibility	Notes
`web-ui`	Browser client. Receives streamed tokens and renders citations	Server-sent events, not polling
`askacme-api`	Session handling and orchestration of one question	Stateless; horizontally scalable
`auth-`	Validates the Okta ID token — signature,	Rejects on any failure. No fallback path

Component	Responsibility	Notes
`middleware`	audience, expiry	
`identity-resolver`	Resolves the signed-in subject to current Entra group membership	5-minute cache (starting value). **Fails closed** — no group claims means no retrieval
`retrieval-svc`	**The enforcement point (ADR-001).** Pre-filters the index on the caller's group claims	Cannot be bypassed: it is the only component with credentials to read the index
`acl-verifier`	Re-checks the caller's access against the source system before a passage is used	Confidential and Restricted tiers only. Internal tier trusts stored labels
`prompt-assembler`	Builds the prompt, fencing retrieved text as data rather than instructions	Injection mitigation lives here — see §6.6

Gateway

Component	Responsibility	Notes
`ai-gateway` (LiteLLM)	The single path out for all model traffic: authentication, token counting, per-team cost tagging, redaction, region routing	Holds all provider credentials. **No other component holds a provider key** — this is what allows PartyPal to be contained (ADR-005)

Model traffic includes **embedding calls**, not only answer generation. Converting a question or a passage into its numeric form is a model call and goes through the gateway like everything else. This matters for Priya's condition: "all model traffic" means all of it.

Data plane

Component	Responsibility	Notes
`index`	Postgres with the pgvector extension. Stores passages, their numeric representations, and inherited access labels	Single index by design (ADR-001). Schema in §6.3
`audit-and-cost-store`	Every refusal, every live check outcome, every prompt and response with token counts and team attribution	**Classified Confidential**, because retrieved passages appear in it. Own access controls and retention period

Ingestion path — scheduled, nightly, nobody waiting

Component	Responsibility	Notes
`scheduler`	Kubernetes CronJob triggering the nightly run	Alerting on a missed or failed run — see ADR-003
`sharepoint-connector`	Reads documents and their effective permissions via Graph API	Read-only
`servicenow-connector`	Reads knowledge articles via REST	Read-only
`armoryos-collector`	Collects the nightly SFTP drop. **No connection to ArmoryOS itself** (ADR-003)	Read-only, one direction
`acl-extractor`	Derives the effective permission set for each item, which becomes the passage's labels	The correctness of this component determines the correctness of enforcement
`chunker`	Splits documents into passages of roughly 500 tokens with about 15% overlap	Both figures are **starting values (ROM)**, tuned against the golden set
`index-writer`	Upserts by source identifier; writes a	Deletion handling matters: a removed

Component	Responsibility	Notes
	tombstone when a source item is deleted	document must stop being retrievable
`change-orchestrator`	Subscribes to source change events. **Re-checks access on any change, not only Confidential material**, and updates stored labels in place	The answer to "how does the index stay current with the source of truth". Without it, an Internal-tier permission change is invisible until the nightly reload

Release gate

Component	Responsibility	Notes
`eval-harness`	Runs the golden-question set — positive, negative and honeypot cases — against a candidate release	**Fails closed.** A failure blocks the release with no discussion. Re-runs after every model version change

---

6.2 Identity flow, end to end

Two identities exist in this system and they are deliberately separate.

The human identity — per question

1. The user reaches `askacme-api` with no session and is redirected to **Okta** (OIDC), the same sign-in used for every other ACME application.
2. Okta returns an ID token. `auth-middleware` validates signature, audience and expiry. Any failure is a rejection, with no fallback.
3. `identity-resolver` takes the verified subject and queries **Entra ID** via Graph for current group membership.
4. Those group claims travel with the question to `retrieval-svc`, which uses them as the filter. **This is the enforcement.**
5. For Confidential and Restricted passages, `acl-verifier` re-checks the caller's access against the source system before the passage is used.
6. **The identity stops here.** Group claims and user identity are used for filtering, logging and cost attribution. They are never placed in the prompt. The model receives passages and a question — never who is asking.

Why Entra for groups and Okta for sign-in. SharePoint's access rules are expressed against Entra groups, so reading group membership from Entra compares like with like. Reading from Okta instead would require a mapping between two group directories, and anything that maps between two lists can drift. *Assumption A6: Okta and Entra membership are consistent, both deriving from Active Directory. To be confirmed with the identity team, including the defined behaviour on divergence.*

Fail-closed behaviour. If Entra is unreachable, `identity-resolver` returns no claims and `retrieval-svc` returns no passages. The system degrades to answering nothing rather than answering without a permission check.

The workload identity — the indexer

`svc-askacme-indexer` is the account the ingestion connectors run as. It is the highest-value non-human identity this programme creates: it reads every in-scope source, including Confidential material, and it exists from the moment loading begins.

Containment, stated explicitly:

Control	Specification

Control	Specification
Permissions	Read-only. **No write permission to any source, anywhere.**
Scope	Enumerated per source, site by site — not tenant-wide. Phase 1 grants cover exactly the four Phase 1 sites
Credentials	Held in CyberArk. Not in code, not in environment variables, not in a container image
Rotation	Quarterly, aligned to the existing access recertification cycle
Network	Kubernetes NetworkPolicy restricting the connector pods to the source endpoints they are scoped to. **No general internet egress**
Separation	Cannot read the index it writes to. Ingestion writes; only `retrieval-svc` reads
Audit	Every read logged, with the source item identifier
Register	Named in the AI asset register and in the risk register as the top non-human identity

Volunteer this, do not wait to be asked. It is the most dangerous part of the design and naming it first is what makes the rest credible.

The alternative that was rejected: reading each source as the asking user would remove the need for this account entirely. It cannot pre-filter a shared index cheaply and would require a live source call for every candidate passage on every question. Rejected on latency and cost, not on security — and conceded as the cleaner design on identity grounds if raised.

6.3 Index schema

Field	Purpose
`passage_id`	Primary key
`source_id`	Stable identifier in the originating system. Used for upsert and deletion
`source_system`	SharePoint, ServiceNow, ArmoryOS
`tier`	Internal / Confidential / Restricted — drives whether live verification applies
`acl_labels`	The inherited permission set. **The filter matches against this**
`passage_text`	The text handed to the model
`embedding`	Numeric representation, pgvector
`document_title`, `document_url`	Citation rendering
`loaded_at`	Drives the declared freshness figure and the data-age note in answers

Deletion is handled by tombstone: when a source item disappears, its passages become non-retrievable on the next run. An index that keeps serving deleted documents is a slower version of the same leak.

6.4 Blast radius and containment

Following the Kubernetes material: you never administer the cluster, you deploy into it. These are the constructs the low-level design specifies.

Construct	Applied as
Namespace	`askacme-prod`, with matching namespaces per environment

Construct	Applied as
ResourceQuota	CPU and memory ceilings on the namespace. Proves AskACME cannot starve the storefront on the same cluster, and is where per-team infrastructure cost attribution physically sits
NetworkPolicy	Only the gateway pod may reach the egress proxy. Retrieval and connector pods have no internet egress at all. Enforced by network rules, not by policy documents
RBAC	Service accounts scoped per component. `retrieval-svc` reads the index; ingestion writes it; neither can read the other's secrets
Readiness probes	No traffic reaches a pod until it passes. A bad release stalls at the first new pod instead of degrading service
PodDisruptionBudget	A minimum available floor, so voluntary disruption cannot take the service to zero
Rollback	`kubectl rollout undo` returns the previous known-good release in seconds, followed by a re-run of the golden set. **This is the rollback plan attached to the CAB request**

Environments: DEV → SIT → UAT → PREPROD → PROD, plus DR at Columbus. Note the SOX constraint: developers cannot deploy their own code to production, so promotion is separated from authorship.

6.5 Streaming and timeout behaviour

Three known traps from the networking material, each with its handling:

Model responses stream for longer than a default idle timeout. A load balancer's default idle timeout is commonly 60 seconds; a long answer can exceed that. The idle timeout on the AskACME load balancer is raised above the maximum expected generation time, and the client uses server-sent events so the connection carries data continuously rather than idling.

Any buffering component turns a live stream into a delayed lump. Buffering is disabled along the response path — gateway, ingress and client. This is a perceived-performance issue rather than a correctness one, but it is the difference between an assistant that feels fast and one that feels broken.

Token traffic is chatty and metered. Every byte is counted at the gateway, which is what makes per-team cost attribution possible and what feeds the cost model in section 8.

6.6 The trap pattern, and its mitigation on the same page

The architecture material names the pattern directly: private data, plus content you do not control, plus a channel out, equals an exfiltration machine — and requires that where all three appear, the mitigation appears alongside.

All three are present here. Private data is the indexed corpus. Content we do not control is the retrieved passages, because anyone who can edit a SharePoint page can put text in it. The channel out is the gateway's egress path.

Mitigations:

Mitigation	Where
Retrieved text is fenced as data and explicitly not treated as instructions	`prompt-assembler`
The model has **no tools and no actions** — it produces text only. There is nothing for injected instructions to operate	System design
No outbound network path from the answering components except the gateway	NetworkPolicy

Mitigation	Where
Attempted-injection cases are permanent members of the golden set	`eval-harness`
Answers cite their sources, so an anomalous answer is traceable to the passage that produced it	`web-ui`

Residual risk, stated: prompt injection is not fully solved by anyone today. The mitigations reduce the blast radius to "the model may produce a wrong answer" rather than "the model may take an action or reach an external endpoint." Named in the risk register.

6.7 The firewall request

The egress path to the model provider is **blocked by default** at ACME's proxy. This is a week-one dependency, not a launch-week discovery, because the queue is 2–3 weeks and a malformed request means starting again.

Field	Value
Source CIDR	The `askacme-prod` pod range — **/24-scoped, not /16.** Requesting a /16 asks for 65,536 hosts and earns a resubmission
Destination CIDR	The provider endpoint range
Port / protocol	443 / TCP
Justification	Sanctioned model access for the AI Enablement Program, via the approved AI gateway, per non-negotiable #1

Submitted day one. A second request covers the EU endpoint in phase 3.

6.8 Where each non-negotiable is enforced

Requirement	Enforced at	How it is proven
All model traffic through the gateway	`ai-gateway`, plus NetworkPolicy denying other egress	No component but the gateway holds a provider key, and no other pod can reach the proxy
Authorization parity	`retrieval-svc`, with `acl-verifier` for higher tiers	Honeypot cases in the golden set; every refusal logged with identity
EU personal data stays in the EU	Region routing at `ai-gateway`	Phase 3 addition; routing rule plus DPIA
Production change through CAB	Release process	RFC with `kubectl rollout undo` plus a golden-set re-run as the rollback
Eval gates	`eval-harness`, failing closed	Blocks the release. Re-runs on every model version change

---

Ends section 6.

Section 7 — Reliability and Quality

Every number in this section is a tolerance that was chosen, priced and can be defended. Each carries a maturity label: **ROM** (rough order of magnitude, ±50%), **refined**, or **validated**. Nothing here is "as high as possible" — an unpriced target is not a target.

The governing principle: **the teeth go on quality, not uptime.** AskACME is an internal assistant used by staff who escalate when unsure. A failed answer that is confidently wrong costs ACME more than an hour of downtime.

7.1 Vocabulary, applied

Term	Meaning here
SLI	What we measure, defined exactly, including where it is measured and over what window
SLO	The internal target we engineer, alert and freeze against
SLA	Any external promise. **AskACME has no SLA** — it is an internal system with no contractual counterparty. If one is ever written it stays looser than the SLO; the gap is the margin

---

7.2 Availability

SLI. Percentage of question requests returning a complete answer or a valid refusal within the latency target, measured at the load balancer, over a rolling 30-day window.

SLO. 99.5% during business hours — 07:00–19:00 ET, Monday to Friday. **[refined]**

Error budget. Business hours are roughly 252 hours per month. 0.5% of that is approximately **76 minutes of unavailability per month.**

Drivers:

1. **Each additional nine costs roughly ten times the last.** 99% permits maintenance windows and human repair in business hours. 99.9% requires redundancy, health checks, zero-downtime deploys and weekend-proof operations. 99.99% requires multi-region failover and recovery with no human in the loop. AskACME does not warrant the third step.
2. **Availability composes in series, and the user's own network sets the ceiling.** A typical ISP is unavailable for far longer per year than a fourth nine would allow. Beyond a point, additional nines are visible only to the dashboard and the CFO.
3. **This is an internal assistant with a human fallback.** Staff who cannot get an answer escalate the way they do today. The failure mode is inconvenience, not a stopped business process.
4. **Business hours, not 24/7, is deliberate.** Out-of-hours availability would require an on-call rota ACME does not have and this programme is not funding. Named explicitly as something not promised — see §7.7.

Error budget policy. Pre-agreed, so it does not require a meeting:

- **Budget healthy** → ship. Take reasonable risks. That is what the budget is for.
- **Budget spent** → feature freeze. Reliability work only until the window refills.

The velocity-versus-reliability argument becomes subtraction, and nobody wins an argument with subtraction.

7.3 Freshness, per source

Content is as fresh as the last load. This is stated per source rather than as a single figure, because the constraints differ.

Source	Target	Margin	Basis
SharePoint — HR policies	24 hours	+6 h before alerting	Nightly load. Policy documents change infrequently **[refined]**
SharePoint — Depot SOPs	24 hours	+6 h	Nightly load **[refined]**
SharePoint — Sales material	**4 hours**	+2 h	Pricing and discount matrices change within a working day, and a stale discount has commercial consequences **[ROM]**
ServiceNow — knowledge articles	24 hours	+6 h	Nightly load. Article changes follow a review cycle **[refined]**
ArmoryOS — rental inventory	**24 hours**	+6 h	**Source-imposed.** The system produces a file once a night; this is the best physically available (ADR-003)

Permissions are not subject to this. Group membership is read live at question time and re-verified against the source for Confidential and Restricted material. **Stale content is an inconvenience; stale permissions are a leak.** That asymmetry is deliberate.

Answers state their data age where the source is ArmoryOS — "as of last night's file." Declared, not apologised for.

A missed load is an alerting condition, not a silent degradation to older data.

7.4 Latency

SLI. Time from request received to first token delivered, and time to complete answer, measured at the load balancer, 95th percentile over a rolling 7-day window.

Measure	Target	Margin	Notes
Time to first token	**3 seconds**	± 1 s	The number that determines whether the system feels responsive **[ROM]**
Complete answer	**15 seconds**	± 5 s	Depends on answer length **[ROM]**
Refusals	**under 2 seconds**	± 0.5 s	A refusal requires no model call at all — the search returns nothing, so there is nothing to send. Faster than an answer by construction **[refined]**

The live permission re-check on Confidential material adds roughly 200–400 ms. Accepted deliberately: the alternative is serving sensitive content on stale labels.

Both time-to-first-token figures are ROM and will be replaced by measurement during Phase 1. They are stated so that Phase 1 has something to measure against, not because they are known.

Two engineering constraints behind these numbers, from the networking material:

- The load balancer idle timeout is raised above maximum expected generation time. A default 60-second idle timeout would kill long answers mid-sentence.
- Buffering is disabled along the response path. One buffering component turns a live stream into a delayed lump, which reads to a user as a broken system.

7.5 Cost ceiling

SLI. Total model spend per calendar month, attributed per team at the gateway.

SLO. $300 per month for the Phase 1 pilot — approximately 70 Service Desk users. **[ROM, ±50%]**

Basis, stated so it can be challenged:

Input	Value	Maturity
Pilot users	70	**[C]** — Service Desk headcount
Adoption at steady state	75% of eligible	**[ROM]**
Questions per active user per working day	8	**[ROM]** — assumption A7, unmeasured
Working days per month	21	**[refined]**
Questions per month at steady state	~8,800	Derived
Model cost per question	~$0.015	**[ROM]** — full derivation in section 8
Retry, failure and eval overhead	+20%	**[ROM]**
Monthly total	**~$158, ceiling set at $300**	**[ROM]**

The ceiling is set at roughly double the expected figure deliberately. The purpose of a ceiling is to catch a runaway, not to predict the bill — a ceiling set at the expected value alerts constantly and gets ignored.

The single largest uncertainty in this proposal is questions per user per day. It is an assumption, not a measurement, and the whole cost model rests on it. This is the primary reason the pilot cohort is the Service Desk: high question volume produces a measured figure within weeks, replacing the assumption the business case depends on.

Enforcement, not just a target. Per-team budgets are set at the gateway. Crossing the ceiling triggers an alert to the named owner, not a silent overrun. This is Priya's condition made mechanical — a cost SLI with a name attached.

Non-model running costs are excluded here and carried in section 8 — compute, database, storage, log retention, and staff time. The ceiling above covers model spend only, and saying so prevents an apparent inconsistency between sections.

7.6 The quality gate — where the real teeth are

This is the tolerance that matters most, and it is enforced as a release gate rather than monitored as a metric.

The golden-question set

Case type	Content	Threshold
Positive	Questions with a known correct answer, per audience and per source	**85% pass [ROM]** — to be agreed with the sponsor and Security before Phase 1 release
Negative	Questions the system must refuse — out of scope, no grounding available	**100%. No exceptions**
Honeypot	The two planted documents, asked by unauthorised personas. Permanent members	**100%. No exceptions**
Injection	Documents containing text attempting to steer the model	**100%. No exceptions**

The named case: Mo Alvarez asking *"any acquisitions coming?"* must return nothing — no answer, no redaction notice, no acknowledgement that a document exists.

The gate

> The set runs on every release and after every model version change. **A failure blocks the release. No debate, no override.**

Why 85% on positive cases is ROM and the rest are absolute. A missed answer fails safe — the user escalates as they do today. A leaked document does not fail safe. The asymmetry in the thresholds reflects the asymmetry in the consequences.

Why the set re-runs on model version change. The provider can change the model beneath us. A version change is a change to the system whether or not ACME initiated it, so it is gated like any other.

This is also the expansion gate. A phase opens only when the set passes in live use at the agreed level, including every refusal case (ADR-004).

7.7 Unwritten expectations, made explicit

The riskiest targets are the ones nobody wrote down. Two examples already exist at ACME: the checkout service carries an implicit 100% availability expectation that nobody measures, so nobody can safely change it; and PartyPal has real dependents with no stated target at all. An unmeasured expectation is still an expectation — it simply cannot be engineered.

The unwritten expectation for AskACME is that answers are correct. Nobody would write "the assistant should be right" into a requirements document, and yet it is the expectation that matters most. §7.6 is that expectation made measurable.

What this proposal deliberately does not promise

Not promised	Because
Availability outside business hours	No on-call rota exists and this programme is not funding one
Live rental inventory	The source produces data once a night (ADR-003)
Booking confirmation	Bookings remain in ArmoryOS. This system informs; it does not transact
That every answerable question will be answered	Retrieval can miss. It fails to a non-answer, not a wrong answer
Customer-facing use	Internal staff only. Staff escalate when unsure; customers would not
Answers from SAP	Excluded by the migration moratorium
That Copilot becomes unblocked	Separate programme, tenant-wide scope. See §2.7

Stating these is not hedging. Each one is a place where an unstated assumption would otherwise have been discovered during peak season.

7.8 Summary of tolerances

Tolerance	Target	Margin	Maturity
Availability	99.5%, business hours	~76 min/month budget	refined

Tolerance	Target	Margin	Maturity
Freshness — SharePoint policy and SOP sources	24 h	+6 h	refined
Freshness — sales material	4 h	+2 h	ROM
Freshness — ArmoryOS	24 h, source-imposed	+6 h	refined
Latency — first token	3 s (p95)	± 1 s	ROM
Latency — complete answer	15 s (p95)	± 5 s	ROM
Latency — refusal	< 2 s	± 0.5 s	refined
Cost — Phase 1 model spend	$300 / month ceiling	± 50%	ROM
Quality — positive cases	85% pass	to be agreed	ROM
Quality — negative, honeypot, injection	100%	none	absolute

Ends section 7.

Section 8 — Business Case

Every figure here traces to §8.1, the measurement table, which states where each input comes from and how it would be replaced by a measured value. Maturity labels throughout: **ROM** (±50%), **refined**, **validated**.

Build costs are not in this section. They are in section 9. This section covers the cost of *running* AskACME. Keeping them separate prevents double counting.

8.1 Measurement table — where every input comes from

#	Input	Value used	Maturity	Source	How it becomes measured
M1	Instruction prompt length	300 tokens	ROM	Design estimate	Logged per call at the gateway from day one
M2	Passages per question	5	ROM	Starting value, ADR-001	Tuned against the golden set; logged per call
M3	Passage length	500 tokens	ROM	Chunker starting value	Logged at load time
M4	Question length	50 tokens	ROM	Design estimate	Logged per call
M5	Conversation history carried	400 tokens	ROM	Design estimate, averaged	Logged per call
M6	Answer length	350 tokens	ROM	Design estimate	Logged per call
M7	Input token rate	$3.00 per million	**ROM — placeholder**	Planning rate for a mid-tier frontier model	**Replaced by the contracted rate once the enterprise agreement clears Legal**
M8	Output token rate	$15.00 per million	**ROM — placeholder**	As above	As above
M9	Embedding rate	$0.13 per million	ROM	As above	As above
M10	Questions per user per working day	8	**ROM — assumption**	Unmeasured	**Measured during Phase 1. This is the primary reason the**

#	Input	Value used	Maturity	Source	How it becomes measured
			A7		**Service Desk is the pilot cohort**
M11	Working days per month	21	refined	Standard	—
M12	Pilot population	70	**[C]**	Service Desk headcount, dossier	—
M13	Blended internal staff cost	$75 per hour, fully loaded	ROM	Planning rate	Confirm with ACME Finance
M14	Retry, failure and eval overhead	+20% on model spend	ROM	Allowance for retries, failed calls, eval runs	Logged at the gateway

M7 and M8 are the two figures most likely to change, because the contracted rate is unknown until the agreement clears. Both are named as placeholders rather than presented as prices.

8.2 The cost of one question

Element	Tokens	Rate	Cost
Embed the question (M4)	50	M9	$0.0000065
Input to the model — instruction (M1) + 5 passages (M2 × M3) + question (M4) + history (M5)	3,250	M7	$0.00975
Output from the model (M6)	350	M8	$0.00525
Model cost per question			**≈ $0.0150**

A refusal costs almost nothing. The search returns no passages, so there is nothing to send to the model — no input tokens, no output tokens. Refusals cost the embedding call only, roughly $0.000007. This is a pleasant property of enforcing at retrieval rather than after generation: the safe path is also the cheap path.

Loading is not a meaningful cost. The Phase 1 corpus is estimated at roughly 3,000 documents, about 12,000 passages, about 6 million tokens. Embedding that once costs approximately **$0.78**. Nightly runs re-embed only changed documents, so ongoing loading cost is negligible. Worth stating, because the intuition that indexing is expensive is wrong here.

8.3 Non-model running costs

The lines that are easy to omit, and where most of the money actually is.

Line	Monthly, Phase 1	Maturity	Note
EKS compute — `askacme-prod` namespace within quota	$250 – 450	ROM	Shared cluster; marginal cost of the namespace
Postgres with pgvector, managed	$300 – 500	ROM	Sized for the Phase 1 corpus
Storage — passages, embeddings, backups	$30 – 60	ROM	Under 100 GB at Phase 1
Splunk ingestion for audit logs	$200 – 400	ROM	**Volume-licensed. Every prompt and response**

Line	Monthly, Phase 1	Maturity	Note
			is logged, so this scales with usage
Log storage and retention	$150 – 300	ROM	Classified Confidential, so retained under the applicable schedule
Data egress	$20 – 50	ROM	Token traffic is chatty and metered
Backup and DR replication to Columbus	$80 – 150	ROM	
Observability — dashboards, alerting	$50 – 100	ROM	
Gateway licensing	$0	refined	LiteLLM is open source. Support cost, if purchased, is not included
Infrastructure subtotal	**$1,080 – 2,010**	ROM	Midpoint ~$1,545

Staff running cost

Role	Allocation	Monthly	Note
Platform engineer — run and operate	0.2 FTE	~$2,600	Business-hours support only, consistent with the 99.5% target
Quality owner — golden set maintenance, eval review	0.1 FTE	~$1,300	Grows with each phase
Staff subtotal	**0.3 FTE**	**~$3,900**	At M13

Permission remediation for later phases is **build** cost, in section 9, not run cost.

8.4 Demand model — month 1 is not month 12

The calendar is real, not notional. Phase 1 goes live 25 September 2026, so run-year one is **October 2026 to September 2027** — and month 1 falls inside the Spooky Freeze. Phase 2 therefore cannot open until the freeze lifts, the gate review completes, and its permission remediation is done.

Adoption ramp per phase: 40% of the eligible population active in month one, 60% in month two, 75% steady. Questions per active user per day: 8 (M10, ROM). Model spend includes the +20% overhead from M14.

Month	Calendar	Phase	Eligible	Active	Questions	Model	Infra	Staff	**Total**
M1	Oct 2026	Phase 1 · **FREEZE**	70	28	4,704	$85	$1,545	$3,900	**$5,530**
M2	Nov 2026	Phase 1 · freeze ends 7 Nov	70	42	7,056	$127	$1,545	$3,900	**$5,572**
M3	Dec 2026	Phase 1 · Phase 2 prep	70	52	8,736	$157	$1,545	$3,900	**$5,602**
M4	Jan 2027	Phase 1 · Phase 2 remediation	70	52	8,736	$157	$1,545	$3,900	**$5,602**
M5	Feb 2027	Phase 2 live	340	136	22,848	$411	$1,850	$3,900	**$6,161**
M6	Mar 2027	Phase 2	340	204	34,272	$617	$1,850	$5,200	**$7,667**
M7	Apr 2027	Phase 2	340	255	42,840	$771	$1,850	$5,200	**$7,821**
M8	May	Phase 2	340	255	42,840	$771	$1,850	$5,200	**$7,821**

Month	Calendar 2027	Phase	Eligible	Active	Questions	Model	Infra	Staff	**Total**
M9	Jun 2027	Phase 2 · Phase 3 prep	340	255	42,840	$771	$1,850	$5,200	**$7,821**
M10	Jul 2027	Phase 3 live	1,200	480	80,640	$1,452	$2,400	$6,500	**$10,352**
M11	Aug 2027	Phase 3	1,200	660	110,880	$1,996	$2,400	$6,500	**$10,896**
M12	Sep 2027	Phase 3	1,200	840	141,120	$2,540	$2,400	$6,500	**$11,440**

Year-one running totals

	Amount	Share
Questions answered	~547,500	
Model spend	**$9,855**	11%
Infrastructure	**$22,630**	25%
Staff — run and operate	**$59,800**	65%
Total year-one running cost	**~$92,300**	

All-in cost per question, year one: approximately $0.17 — against a model cost of $0.015. **The model is about 9% of the true unit cost.**

Three things the shape of this table shows:

Month 1 is the freeze. Usage begins during five weeks in which nothing may change. That is not an accident of scheduling — it is the deliberate consequence of going live on 25 September, and it is what turns the freeze into a clean five-week measurement window for assumption A7.

Month 12 is roughly double month 1 in cost and thirty times in volume. The two do not move together because fixed staff and infrastructure dominate, which is the point §8.5 makes.

Staff cost steps, it does not scale. It rises at month 6 and month 10 as phases open, because the allocation changes in whole increments rather than smoothly with usage.

8.5 Sensitivity — the largest driver

The largest cost driver is staff time, not tokens. Staff is 65% of year-one running cost; model spend is 11%. Any conversation about reducing AskACME's cost that starts with the model is looking in the wrong place.

Head-to-head on the largest driver

	Option A — dedicated 0.3 FTE	**Option B — absorb into the existing platform team**
Year-one cost	~$59,800	~$12,000 of displaced capacity
Named owner	Yes	No
Response to an incident	Within business hours, as committed	Best effort, behind other priorities
Golden set maintained	Yes, by an accountable person	Likely to lapse
Risk	Cost is visible and attributable	**Recreates the exact failure in findings 3 and 6** — a system with real dependents and no owner of record

Recommendation: Option A. The saving in Option B is real, and it is roughly $48,000 in year one. It is declined because this programme's entire justification is that ACME has AI systems nobody owns. Delivering another one, and saving money by doing so, would be incoherent.

This is the strongest cost argument available, because it is not a technical claim. It is the needs analysis applied to the budget.

Sensitivity on the largest uncertainty

M10 — questions per user per day — is unmeasured and everything volumetric rests on it.

M10 value	Year-one questions	Model spend	Total running cost	Change in total
4 per day	~273,800	$4,928	~$87,400	−5%
8 per day (base)	~547,500	$9,855	~$92,300	—
16 per day	~1,095,000	$19,710	~$102,100	+11%
32 per day	~2,190,000	$39,421	~$121,900	+32%

The finding: the biggest uncertainty in the model barely moves the answer. Doubling usage raises total running cost by 11%; quadrupling it raises it by 32%. Fixed staff and infrastructure dominate throughout. The proposal is therefore robust to being wrong about M10 — which is the useful thing to know about an assumption you cannot yet measure.

What would change the answer. At roughly 40 questions per user per day across 1,200 users, model spend overtakes infrastructure and the economics shift. At that point the phase 2 optimisation earns its place: route routine questions to a smaller, cheaper model and reserve the expensive one for hard ones, with misroutes failing *toward* the expensive model. That is a planned improvement, not a Phase 1 requirement, and it is deliberately deferred until measured traffic shows what "routine" looks like.

Sensitivity on the placeholder rates

M7 and M8 are unknown until the agreement clears Legal. If the contracted rate is double the placeholder, year-one model spend rises from $9,855 to $19,710 — an 11% increase in total running cost. **The commercial terms of the agreement are not a material risk to this business case.** The *timing* of the agreement is, and that is a schedule risk in section 10, not a cost risk.

8.6 Benefit — what is countable

The pilot cohort was chosen partly because its benefit is measurable rather than asserted.

Measure	How counted	Status
Service Desk tickets resolved without escalation	Escalation rate before and during the pilot, from ServiceNow	Baseline to be taken before Phase 1
Time to first response on knowledge-type tickets	ServiceNow timestamps	Baseline to be taken before Phase 1
Reduction in unsanctioned model use	Egress proxy logs for consumer AI endpoints, before and after UC-07	Measurable, but attribution is imperfect
Azure workspace retired	$400/month, ~$4,800/year	Immediate and certain

No benefit figure is claimed in this proposal. The baselines do not exist yet, and inventing a productivity percentage would be the least defensible number in the document. What is committed is the measurement: baselines taken before Phase 1, compared during it, and reported at the phase gate.

The honest framing for the sponsor: the primary return in year one is risk reduction, not productivity. Confidential material stops leaving through unsanctioned channels, an unowned production system gains an owner, and ACME acquires cost attribution it currently does not have. Productivity benefit is plausible and will be measured, not promised.

8.7 Cost attribution — Priya's condition, mechanically

Requirement	Implementation
Per-team model spend	Every gateway call tagged with the calling team; monthly report by cost centre
Per-team budgets	Ceilings set at the gateway; crossing one alerts the named owner rather than overrunning silently
Infrastructure attribution	Namespace-level resource quota, reported per namespace
No untagged spend	No component other than the gateway holds a provider credential, so no call can bypass tagging

This is what was missing when the Azure workspace billed $400 a month for two years unnoticed (finding 5).

8.8 Total cost of ownership, year one

The sections of this proposal are ordered as the engagement requires — needs, architecture, cost, effort, plan. **The derivation runs the other way:** the architecture determines the effort, the effort determines the build cost, and the build cost plus the running cost is what ACME actually spends. This section closes that loop so the business case is complete rather than partial.

Component	Amount	Derived in	Maturity
Phase 1 build — 213.9 person-days (1,711 hours) at $600/day	$128,340	§9.3	ROM
Phase 1 contingency — 20%, visible, not hidden in estimates	$25,668	§9.4	ROM
Phase 1 build subtotal — 2,054 hours	**$154,008**	§9.4	ROM
Model spend, year one — all phases as they come online	$9,855	§8.4	ROM
Infrastructure, year one — all phases	$22,630	§8.3, §8.4	ROM
Staff to run and operate, year one — all phases	$59,800	§8.3, §8.4	ROM
Running subtotal	**$92,285**	§8.4	ROM
What ACME spends in year one	**~$246,300**		**ROM, ±50%**

Scope of this figure. Phase 1's build — including its permission remediation — plus running costs across all three phases as they come online. It is **not** the whole-programme cost: Phase 2 and Phase 3 each carry their own build effort, estimated at their gate using Phase 1's measured cost per site (§9.6).

No double counting. Build effort is August–September 2026, before go-live. Running cost is October 2026 to September 2027, from go-live. They are different people doing different work in different months.

Phases 2 and 3 build cost is not included, and deliberately so — it is estimated at each gate using Phase 1's measured cost per site (§9.6). Presenting a three-phase build figure now would mean multiplying an unmeasured number and calling it a plan.

Where the money actually goes

	Share of year-one total
Building it — people	~63%
Running it — people	~24%
Infrastructure	~9%
The AI model	**~4%**

People are roughly 87% of year-one cost. The model is about 4%. That single line is the most useful thing in this business case, and it is the answer to any question that opens with token prices.

8.9 Delivery approach — and why not agile

This is a **staged waterfall with gates**: needs analysis, then architecture, then cost and effort, then build, then a release gate, then phased expansion. Each stage's output is the next stage's input, and each phase boundary is a decision point with a stated pass condition (ADR-004).

That is a choice, and it deserves a driver rather than being a default:

The permission remediation cannot be iterated. Authorization parity either holds or it does not. There is no partially-correct access map to ship and refine, because the failure mode is a disclosure that cannot be withdrawn.

The constraints are fixed dates, not backlog priorities. A 38-day freeze, a Thursday CAB, a 2–3 week firewall queue and a stalled legal agreement are sequencing problems. They reward planning, not responsiveness.

Change control is external to the delivery team. Every production change goes through CAB with an RFC and a rollback plan, and SOX separation of duties means developers cannot deploy their own code. Continuous deployment is not available to this programme regardless of preference.

Where it is iterative anyway. Within Phase 1 the retrieval quality loop is genuinely iterative: chunk size, passage count and prompt structure are tuned against the golden set and re-measured. And the phase gates are inspect-and-decide points — each phase is estimated only when the previous one has produced measured figures. So the shape is waterfall at the programme level and iterative inside a phase, which is what the constraints allow.

Ends section 8.

Section 9 — Level of Effort

Scope of this section: **Phase 1 build only.** Phases 2 and 3 are estimated at the phase gate, once Phase 1 has produced measured figures. Running costs are in section 8 and are not repeated here.

Estimating method. Every work package carries three points — optimistic, likely, pessimistic — and a weighted mean using PERT: **(O + 4L + P) ÷ 6**. Three-point estimating is used because single-point estimates hide their own uncertainty, and the spread between O and P is itself information: a wide spread signals a package that needs discovery before it can be committed.

Figures are given in person-days and in hours — one person-day is 8 hours, so 213.9 person-days is 1,711 hours, and the build total of 256.7 days is 2,054 hours. Effort is not duration — see section 10, where the firewall queue takes three weeks of calendar time and four days of effort.

Where this lands. The build figure derived here is carried into §8.8, which adds it to the running cost to give the year-one total cost of ownership. The chain is: architecture determines effort, effort determines build cost, build plus run is what ACME spends.

9.1 Team census

Drawn from ACME's IT organisation of approximately 310 staff.

Team	Headcount	Role in Phase 1	Phase 1 days	**Hours**
Application Development	60	Connectors, retrieval service, answer service, UI, eval harness	~89 days	**~712**
Infrastructure & Cloud	55	Namespace and quotas, data plane, network requests, promotion to production	~40 days	**~320**
Security	25	Permission remediation, identity integration, enforcement review, negative test authorship	~35 days	**~280**
Data & Analytics	30	Gateway deployment, cost attribution, index sizing	~20 days	**~160**
PMO	20	Programme management, DPIA and DPA escalation, CAB coordination, adoption	~40 days	**~320**
Service Desk	70	Golden-question authorship, pilot participation, baseline metrics	~10 days	**~80**
Enterprise Architecture	6	ARB review of HLA, LLA and decision records	~3 days	**~24**
Legal & DPO	—	DPIA, DPA clause negotiation	~5 days	**~40**
Events Operations	—	PartyPal containment: owner identification, dependency documentation	~3 days	**~24**
SAP team	—	**None. Zero by design**	**0 days**	**0**
M365 team	—	**None. Copilot is out of scope**	**0 days**	**0**
it-legacy (Gene Podowski)	—	**None in Phase 1.** ArmoryOS is Phase 3	**0 days**	**0**

Zero-effort entries, with reasons written down

Team	Effort	Reason
SAP	**0**	Project Fresh Start migration moratorium prohibits new integrations. No SAP source is in scope in any phase. If financial context is ever required it arrives via Snowflake, already a sanctioned path. **Stated explicitly because a zero with no reason reads as an omission**
M365	**0**	Copilot is a separate programme owned by the M365 team (§2.7). No dependency in either direction
it-legacy	**0 in Phase 1**	ArmoryOS enters in Phase 3. Gene's involvement is then a single scheduled review, never a running dependency (ADR-003)

9.2 Architecture-to-team mapping

Every component in the low-level design implicates a team, and every team in the census owns at least one component. This mapping is the check that the estimate matches the architecture rather than being invented alongside it.

Component (DWG A-200)	Work package	Owning team	Reviewing team
`web-ui`	WP-08	App Dev	—
`askacme-api`	WP-07	App Dev	Enterprise Architecture
`auth-middleware`	WP-02	Security	App Dev
`identity-resolver`	WP-02	Security	Infra
`retrieval-svc` — enforcement point	WP-05	App Dev	**Security (mandatory)**
`acl-verifier`	WP-05	App Dev	**Security (mandatory)**
`prompt-assembler`	WP-07	App Dev	Security
`ai-gateway` (LiteLLM)	WP-06	**Data & Analytics**	Security, Infra
`index` — Postgres + pgvector	WP-03	Data & Analytics	Infra
`audit-and-cost-store`	WP-10	Infra	Security, Data
`scheduler`	WP-04	App Dev	Infra
`sharepoint-connector`	WP-04	App Dev	Security
`servicenow-connector`	WP-04	App Dev	—
`armoryos-collector`	**Phase 3**	App Dev	it-legacy
`acl-extractor`	WP-04	App Dev	**Security (mandatory)**
`chunker`	WP-04	App Dev	—
`index-writer`	WP-04	App Dev	Data
`eval-harness`	WP-09	App Dev	Security, Service Desk
Namespace, quotas, network policy, RBAC	WP-10	**Infra**	Security
Egress path and firewall requests	WP-11	Infra	Security
`svc-askacme-indexer` identity and containment	WP-02	**Security**	Infra

Three components carry a mandatory Security review: the enforcement point, the live verifier, and the permission extractor. Those three determine whether authorization parity holds, so App Dev builds them and Security signs them off. This separation exists so that no single team both builds and approves the control.

9.3 Work packages and estimates

WP	Work package	Owner	O	L	P	**PERT**	Maturity
WP-01	Permission discovery and remediation — 4 Phase 1 sites	Security	15	25	45	**26.7**	**ROM**
WP-02	Identity integration — Okta sign-in, Entra group resolution, indexer identity and containment	Security	6	10	20	**11.0**	refined
WP-03	Index and data plane — Postgres, pgvector, schema, backup	Data	5	8	15	**8.7**	refined

WP	Work package	Owner	O	L	P	**PERT**	Maturity
WP-04	Ingestion — SharePoint and ServiceNow connectors, permission extraction, chunking, writer	App Dev	12	20	35	**21.2**	refined
WP-05	Retrieval service — the enforcement point, plus live verifier	App Dev	10	18	32	**19.0**	refined
WP-06	AI gateway — deploy, configure, credentials, cost tagging, region routing	Data	5	9	18	**9.8**	refined
WP-07	Answer service — prompt assembly, streaming, citations	App Dev	6	10	18	**10.7**	refined
WP-08	Web interface	App Dev	8	13	22	**13.7**	refined
WP-09	Eval harness and golden-question set — positive, negative, honeypot, injection	App Dev	8	14	25	**14.8**	**ROM**
WP-10	Observability — namespace, quotas, network policy, logging, cost attribution, dashboards	Infra	5	9	16	**9.5**	refined
WP-11	Network — firewall requests, egress path, proxy allowlist	Infra	2	4	8	**4.3**	refined
WP-12	DPIA and DPA escalation	PMO	3	6	15	**7.0**	**ROM**
WP-13	PartyPal containment — owner, corporate credential behind the gateway, logging, documentation	App Dev	4	7	14	**7.7**	refined
WP-14	Azure workspace retirement — register, confirm no dependants, retire with sign-off	Data	1	2	5	**2.3**	refined
WP-15	RFC preparation, CAB, promotion to production	PMO	3	5	10	**5.5**	refined
WP-16	Adoption — comms, training, baseline metrics, pilot support	PMO	5	9	16	**9.5**	refined
WP-17	Programme management	PMO	15	22	35	**23.0**	refined
WP-19	Change orchestrator — subscribe to source change events, re-check access on any change, update labels in place	App Dev	5	9	16	**9.5**	ROM
WP-18	**SAP integration**	—	**0**	**0**	**0**	**0**	validated — moratorium
	Subtotal		**113**	**190**	**340**	**213.9**	
	In hours					**1,711**	

The three widest spreads, and why

WP-01, permission remediation — 15 to 45 days. A three-fold spread, and the widest in the plan. The reason is assumption A2: we do not know what is actually wrong with these sites' access rules, only that Security found the tenant-wide picture serious enough to block Copilot for five months. The spread *is* the honest answer. Narrowing it requires discovery, and discovery is the first activity in the plan.

WP-12, DPIA and DPA — 3 to 15 days. Effort is small; the uncertainty is that neither is fully within ACME's control. The DPA is stalled over a clause. This is a schedule risk more than an effort risk, and it is carried as such in section 10.

WP-09, eval harness and golden set — 8 to 25 days. Writing the harness is straightforward. Agreeing the question set with Security, and getting the pass threshold signed off, is the variable part.

9.4 Contingency

	Person-days	**Hours**	Cost at $600/day
Work package subtotal (PERT)	213.9	**1,711**	$128,340
Contingency — 20%, visible	**42.8**	**342**	**$25,668**
Phase 1 build total	**256.7**	**2,054**	**$154,008**

In plain terms: roughly **2,050 hours** of ACME staff time to build Phase 1 — about **1.2 person-years** if one person did it alone, spread across six teams over eight and a half weeks. The hourly basis is $75, fully loaded (M13), so $600 a working day.

Contingency is one visible line. It is not distributed inside task estimates. Padding hidden in individual packages destroys the meaning of every number around it and makes the plan impossible to manage — you can never tell whether a package is late or was simply padded.

Why 20%, sized against the risk register. Three risks account for most of it:

Risk	Why it draws on contingency
R-03 — permission faults more extensive than estimated	Directly extends WP-01, the widest-spread package
R-07 — eval gate not passed on first attempt	Rework in WP-04, WP-05 and WP-09
R-04 — site owners unavailable for sign-off	Extends WP-01's duration and therefore its supervision effort

What contingency does not cover: the DPA failing to clear (R-01). That is not an effort overrun, it is a stop. Its response is the replan decision in section 10, not money.

Governance. Contingency is released by the programme sponsor against a named risk that has materialised, and drawdown is reported at each phase gate. Unused contingency is returned, not absorbed.

9.5 Effort by team

Team	Person-days	Share
Application Development	~98	46%
Infrastructure & Cloud	~40	20%
PMO	~40	20%
Security	~35	17%
Data & Analytics	~20	10%
Service Desk	~10	5%
Legal & DPO	~5	2%
Enterprise Architecture	~3	1%
Events Operations	~3	1%

Totals exceed 100% because several packages are jointly staffed; the PERT subtotal in §9.3 is authoritative.

The observation worth making: Security and PMO together account for roughly 37% of Phase 1 effort, against Application Development's 44%. Slightly more than a third of this programme is governance, permissions and process rather than writing software. That ratio is not an accident of estimating — it is finding 6 expressed as a resource plan. If the ratio looked like a normal software project, the estimate would be wrong.

9.6 Phases 2 and 3 — deliberately not estimated

No figure is given for Phase 2 or Phase 3 in this proposal.

Why. The dominant cost in each phase is permission remediation, and its cost per site is unknown (assumption A3). Phase 1 measures it across four sites. Estimating Phase 2 now would mean multiplying an unmeasured figure by a larger number of sites and presenting the result as a plan.

What is committed instead: each phase is estimated at its gate, using Phase 1's measured cost per site, and the estimate is presented before the phase is authorised. Phase 2 additionally carries executive sign-off effort for the Corp Dev site, and Phase 3 carries a new class of work — record-level permission handling for Salesforce, and bespoke ingestion for ArmoryOS.

A rough order of magnitude, clearly labelled as such: Phase 2 is expected to be smaller than Phase 1 in build terms, since it reuses the same connector and adds no new plumbing, but larger in remediation terms. Phase 3 is expected to be the largest, because both of its sources introduce genuinely new mechanisms. **These are directional statements, not estimates, and should not be quoted as numbers.**

Ends section 9.

Section 10 — Project Plan

Method: the immovable objects are drawn first, then the work is fitted around them. A plan that schedules work and then discovers the calendar is a plan that gets replanned.

Assumed start: **Monday 3 August 2026.** All dates shift with the actual start.

10.1 The immovable objects, drawn first

Object	Dates	Effect on this plan
Spooky Freeze	**1 October – 7 November 2026.** Zero production change. Halloween ≈ 38% of revenue	**Phase 1 must be in production before 1 October, or go-live moves to after 7 November.** There is no third option
CAB	Thursdays, 10:00 ET. RFC without a rollback plan is rejected	Production release must align to a Thursday. Available Thursdays before the freeze: 3, 10, 17, **24 September**
Firewall queue	2–3 weeks per request, via ServiceNow. Malformed request means resubmission	Submitted **week 1**. Effort is 4 days; duration is 3 weeks. These are different things
DPIA	Required before new processing of personal data. Has lead time	Filed **week 1**, regardless of which sources are live
Enterprise AI	Stalled in Legal over the no-training-on-	**On the critical path.** Escalated to the sponsor in

Object	Dates	Effect on this plan
agreement (DPA)	our-data clause. Duration outside ACME's control	week 1. **No sanctioned model access until it clears**
SOX separation of duties	Developers cannot deploy their own code to production	Promotion to production is performed by Infrastructure & Cloud, not by the authoring team
Site owner availability	Not a system constraint, but a real one	Permission sign-off meetings booked in week 1 for weeks 2–3

Available working weeks before the freeze: 8.5. That is the whole plan constraint. Everything below is fitted into it.

10.2 Dependency logic — predecessors, with matching chart IDs

Every task carries an ID matching `docs/arch/cal.drawio`, so the chart and the table cannot drift apart. **Dependencies in the chart are structural** — expressed as `after <id>` rather than as fixed dates — so if a predecessor slips, everything downstream of it moves with it. Only the immovable objects carry fixed dates.

ID	Task	Duration	Cannot start until	Why
`dpa`	DPA escalated to sponsor	~30 d	—	Week 1, no predecessor. Duration is *when a decision is needed*, not a forecast of Legal
`fw`	Firewall request in queue	~18 d	—	Week 1. External queue: 4 days of effort, 3 weeks of waiting
`dpia`	DPIA filed	~22 d	—	Week 1. Has lead time, so it starts before it is needed
`disc`	Permission discovery, 4 sites	5 d	Site owners booked	Discovery is first so assumption A2 resolves in week 2, not week 6
`rem`	Remediation with site owners	5 d	**`disc`**	You cannot correct access rules you have not yet enumerated
`idx`	Index, schema, data plane	5 d	—	Independent of permissions work
`ident`	Indexer identity + containment	5 d	—	Must exist before anything reads a source
`gw`	Gateway deployed and configured	7 d	—	Independent. Needed early because containment depends on it
`conn`	Connectors + permission extraction	10 d	**`idx`, `ident`**	Nowhere to write to, and no identity to read with, until both exist
`retr`	Retrieval service — enforcement point	7 d	**`conn`**	Cannot filter an index that has no labelled passages
`ui`	Answer service, prompt assembly, UI	6 d	**`conn`**	Runs in parallel with `retr` against a stub, then integrates
`load`	First load with real access labels	2 d	**`conn`, `rem`**	Needs both a working connector **and** corrected permissions. Loading before remediation would bake in the wrong labels

ID	Task	Duration	Cannot start until	Why
`gs`	Golden question set authored	8 d	**`conn`**	Questions need known answers, so sources must be loaded first
`az`	Azure workspace retired	5 d	Owner identified	Independent of the build
`pp`	PartyPal containment	5 d	**`gw`**	The personal credential is replaced with a corporate one *held by the gateway* — so the gateway must exist first
`prom`	Promotion to SIT, UAT, PREPROD	3 d	**`retr`**, **`ui`**	Nothing to promote until the path works end to end
`rb`	Rollback rehearsal — code and data	3 d	**`prom`**	Rehearsed in a production-equivalent environment, not in DEV
`eval`	Eval gate run in PREPROD	5 d	**`gng`** (go/no-go)	Only run once the decision to proceed is taken
`rfc`	RFC prepared and submitted	3 d	**`m8`** (gate passed)	The gate result is a required attachment. No evidence, no RFC
`m9`	CAB approval	—	**`rfc`** and a Thursday	Cannot precede the fixed CAB slot
`m10`	Production go-live	—	**`m9`**	Promotion performed by Infra, not the authoring team (SOX)
`hc`	Hypercare	3 d	**`m10`**	3 working days, then the freeze
Phase 2 start	—	—	Phase 1 golden set passing **in production** at the agreed level	ADR-004 — the gate is verifiable, not a promise
PartyPal retirement	—	—	Phase 3 delivered	Booking questions need rental data (ADR-005)

The three dependencies that matter most

`load` after `rem`. Loading before remediation would copy the wrong access rules into the index and enforce them faithfully. This single link is why permission work sits upstream of go-live rather than running alongside it.

`pp` after `gw`. PartyPal's containment is not independent housekeeping — it needs the gateway to hold the corporate credential. That is what makes the 30-day commitment dependent on the gateway landing in week 3.

`rfc` after `m8`. The eval gate is not a status report. Its evidence is an attachment the RFC cannot be submitted without, so a failed gate stops the release path rather than being noted in it.

One dependency deliberately broken

Development does not wait for the DPA. `idx`, `ident`, `gw`, `conn`, `retr` and `ui` all proceed using **synthetic documents** — invented content of the same shape as the real thing. Only calls carrying actual ACME data require the signed agreement.

Without this, the entire build would queue behind a legal negotiation ACME does not control, and Phase 1 could not fit before the freeze. It is the single most valuable piece of sequencing in the plan.

10.3 The schedule

*Chart: **DWG A-300**, source of record* `docs/arch/cal.drawio`.

Items marked `crit` are on the critical path. Milestones are diamonds. The freeze is drawn first, before any work is scheduled around it — which is the method this section opened with.

Three things to read off the chart:

The freeze is a wall, not a period of reduced activity. Nothing production-affecting crosses 1 October. Every dependency to the left of it either completes or moves to the right of 7 November.

The DPA bar runs from week 1 to the go/no-go and is marked critical. It is the longest critical item and the only one whose duration ACME does not control. Its length on the chart is an estimate of when a decision is needed, not of when Legal will finish.

The eval gate appears as a milestone with a dependent successor. M8 must complete before the RFC can be submitted, and the RFC must be accepted before the CAB milestone. A quality gate that nothing depends on is a status report; this one blocks the release path.

Note on the last section of the chart. The no-go branch is drawn deliberately. A plan that shows only the intended path is a forecast; one that shows the alternative is a plan.

10.4 Week by week

Week	Dates	Activity	Milestone
W1	3–7 Aug	**External queues entered.** Firewall requests submitted (correct CIDR, first time). DPIA filed. **DPA escalated to sponsor.** Site owner meetings booked. Service Desk baseline metrics captured. Namespace and quotas requested	**M1 — queues entered, clock started**
W2	10–14 Aug	Permission discovery on 4 sites: enumerate effective access. Index and schema built. Indexer identity created and scoped. Gateway deployed to DEV	**M2 — permission picture known**
W3	17–21 Aug	Permission remediation with site owners; access map signed off. Connectors built. Azure workspace retirement (register, confirm, retire)	**M3 — access map signed off**
W4	24–28 Aug	Egress path expected open. Loading runs into DEV with real labels. Retrieval service and enforcement point built. **PartyPal containment complete**	**M4 — egress open; PartyPal contained (30-day commitment met)**
W5	31 Aug – 4 Sep	Answer service, prompt assembly, UI. Golden-question set authored with Service Desk and Security. End-to-end working in DEV on synthetic content	**M5 — end-to-end in DEV**
W6	7–11 Sep	Promotion to SIT and UAT. Golden set agreed and pass threshold signed off by Security. Observability, cost attribution, dashboards live. **Go / no-go decision, Friday 11 September**	**M6 — golden set signed off. M7 — go/no-go**
W7	14–18 Sep	PREPROD. **Eval gate run: positive, negative, honeypot, injection.** Fix and re-run as needed. Rollback rehearsed, including data restore	**M8 — eval gate passed in PREPROD**
W8	21–25 Sep	RFC submitted with eval evidence and rollback plan. **CAB Thursday 24 September.** Production deployment Friday 25	**M9 — CAB approved. M10 — production go-live**

Week	Dates	Activity	Milestone
		September by Infrastructure	
W9	28–30 Sep	Hypercare: 3 working days before the freeze. Daily eval runs, cost and latency monitored against tolerances	**M11 — Phase 1 live and stable**
—	**1 Oct – 7 Nov**	**FREEZE. Zero change.** Monitoring only. Pilot usage continues; measured question volume replaces assumption A7	**M12 — A7 measured**
W10+	from 10 Nov	Phase 1 gate review against the golden set in production. Phase 2 estimated using Phase 1's measured cost per site, then authorised	**M13 — Phase 2 authorised or declined**

10.5 The critical path

Marked path: DPA escalation → DPA cleared → gateway configured with production credentials → eval gate passed → CAB Thursday 24 September → production before 1 October.

Position	Activity	Float	Why it is on the path
1	**DPA clearance**	**Zero, and outside ACME's control**	No sanctioned model access on real data without it. Everything downstream waits
2	Gateway configured with production credentials	Zero	Requires the DPA and the open egress path
3	**Eval gate passed in PREPROD**	~4 days	Its evidence is a required attachment to the RFC
4	**CAB Thursday 24 September**	**Zero — a fixed date**	The last Thursday before the freeze. The next one, 1 October, is inside it
5	Production deployment	4 working days	Must complete before 1 October

Two near-critical paths worth watching:

The **firewall request** has roughly one week of float against a 2–3 week queue. If it is rejected for a malformed CIDR, resubmission consumes the float entirely and it joins the critical path. This is why the request format is specified precisely in §6.7 and submitted on day one.

Permission remediation has float in effort terms but is constrained by site owner availability, which the programme does not control. Meetings are booked in week 1 for exactly this reason.

10.6 The go / no-go decision — Friday 11 September

A named decision point, so that a slip is a decision rather than a discovery.

Assessed on that date:

Question	If no
Has the DPA cleared, or is clearance credibly within 2 weeks?	No-go
Is the egress path open?	No-go
Is the access map signed off for all 4 sites?	No-go
Is the end-to-end path working in UAT?	No-go
Is the golden set agreed with a signed-off threshold?	No-go

If go: proceed to PREPROD, eval gate in W7, CAB on 24 September.

If no-go: Phase 1 production go-live moves to **week commencing 9 November**, immediately after the freeze. First available CAB is Thursday 12 November.

Why declaring this now matters. The alternative is arriving at 24 September, missing the CAB, and going live inside the freeze — a canon violation. Naming the decision point converts that from an incident into a planned branch. **Attempting to squeeze a release into the freeze is not on the table under any circumstances.**

And a genuine benefit of the no-go branch: a November go-live has clear air until the following October, no peak-season pressure during hypercare, and Phase 2 immediately behind it. It is a worse outcome, not a disaster.

10.7 Hypercare and the freeze

Hypercare: 28–30 September, three working days before the freeze begins.

Activity	Frequency
Golden set run	Daily
Cost against the $300 ceiling	Daily
Latency and availability against tolerances	Daily
Refusal log review by Security	Daily during hypercare, then weekly
Pilot feedback session with Service Desk	End of each day

The freeze is used, not merely endured. From 1 October the system runs unchanged for five weeks with real users. That produces exactly what the business case lacks: a measured figure for questions per user per day (assumption A7), real latency distributions, real cost, and a real refusal log — with no code changes confounding the measurement.

So the freeze is a five-week observation window, and Phase 2's estimate is built on it. That is a considerably better position than estimating Phase 2 from a two-week pilot.

A risk to state plainly: if something breaks during the freeze, only an Emergency change can fix it, and that requires the same rollback discipline under time pressure. This is why rollback is rehearsed in W7 rather than documented and hoped for.

10.8 Milestones summary

ID	Milestone	Target
M1	External queues entered — firewall, DPIA, DPA escalated	W1, 7 Aug
M2	Permission picture known across 4 sites	W2, 14 Aug
M3	Access map signed off by site owners	W3, 21 Aug
M4	Egress path open · **PartyPal contained**	W4, 28 Aug
M5	End-to-end working in DEV	W5, 4 Sep
M6	Golden set agreed, threshold signed off by Security	W6, 11 Sep
M7	**Go / no-go decision**	W6, 11 Sep
M8	**Eval gate passed in PREPROD**	W7, 18 Sep
M9	CAB approval	Thu 24 Sep
M10	**Phase 1 in production**	Fri 25 Sep

ID	Milestone	Target
M11	Hypercare complete, stable into the freeze	30 Sep
M12	Assumption A7 measured from real usage	7 Nov
M13	Phase 1 gate review · Phase 2 authorised or declined	from 10 Nov

M8 is a gate, not a report. The eval gate appears on the chart as a milestone with a dependent successor: the RFC cannot be submitted without its evidence. A quality gate that does not block anything is a status update.

10.9 Canon compliance

Stated explicitly, because a canon violation is fatal to this section.

Constraint	Compliance
No production change 1 Oct – 7 Nov	Go-live before 1 Oct, or after 7 Nov. No third branch
No new SAP integration	**Zero SAP effort in every phase.** Snowflake named as the sanctioned route if financial context is ever required
Nothing replaced, only integrated with	No system is removed or replaced. SharePoint, ServiceNow, ArmoryOS, Okta, Entra all remain and are read from
Do not touch the checkout service	Nothing in this plan approaches the payment path
CAB approves all production change	Every production release goes via RFC to a Thursday CAB
Developers cannot deploy to production	Promotion performed by Infrastructure & Cloud
ArmoryOS via nightly batch only	Phase 3, file collection only, no connection to the system (ADR-003)
Legal hold respected	Trebuchet claims file excluded indefinitely

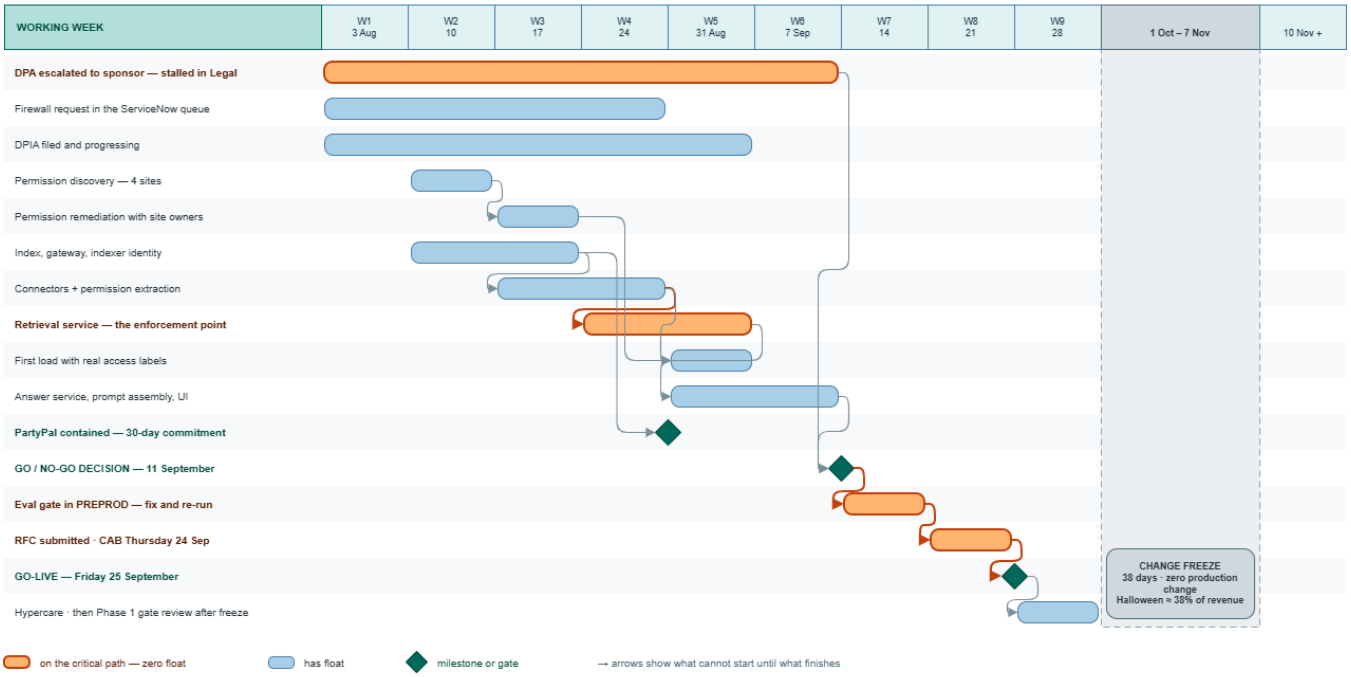
---

Ends section 10.

▼ · DWG A-300 · PHASE 1 SCHEDULE

AskACME — Phase 1 schedule

DWG A-300 · Rev G · immovable objects drawn first · orange = critical path · arrows show what cannot start until what finishes



THE CRITICAL CHAIN DPA cleared → go/no-go → eval gate passed → RFC to CAB Thursday 24 Sep → live Friday 25 Sep
The DPA has zero float and its duration is outside ACME's control — which is why the 11 September go/no-go exists. If it has not cleared, Phase 1 goes live from 9 November.
Releasing inside the freeze is not on the table. The freeze then becomes a five-week observation window, which is how the demand assumption gets measured.
Three tasks start in week one because they are queues rather than work: the agreement in Legal, the firewall request, and the DPIA. Everything else is work we control.

Section 11 — Risk Register

Scoring: likelihood and impact each **Low / Medium / High**. Every risk has a **named owner** and a **trigger** — the observable event that means the response starts. A risk without a trigger is a worry.

Risks marked **[CTG]** are the ones the 20% contingency in §9.4 is sized against.

11.1 Register

ID	Risk	L	I	Owner	Mitigation	Trigger
R-01	**The enterprise AI agreement does not clear Legal in time.** No sanctioned model access on company data, so Phase 1 cannot go live	**H**	**H**	Dana Okafor (sponsor)	Escalated week 1. Build proceeds on synthetic content so the schedule is not idle. Self-hosting in the Łódź footprint named as the fallback (ADR-002), with a cost model that would change materially	Not cleared, and not credibly within 2 weeks, at the **11 September go/no-go**
R-02	**Firewall request rejected** — wrong CIDR scope or wrong form. Resubmission costs 2–3 weeks and consumes all float	**M**	**H**	Infra & Cloud lead	Request format specified in §6.7 with a /24 pod range, not /16. Submitted day 1. Reviewed by Security before submission	Rejection notice, or no movement in the ServiceNow queue after 10 working days
R-03	**Permission faults more extensive than estimated.** WP-01 overruns; assumption A2 proves optimistic	**H**	**M**	Marcus Reyes (CISO)	Three-point estimate already spans 15–45 days. Discovery is the first activity, so the picture is known in W2 rather than W6. **[CTG]**	Discovery in W2 shows more than 40 unique permission grants requiring remediation across the 4 sites
R-04	**Site owners unavailable** to review and sign off the access map	**M**	**M**	PMO lead	Meetings booked in W1 for W2–W3. Sponsor escalation path named in advance. **[CTG]**	Any site owner has not confirmed attendance by end of W1
R-05	**Prompt injection via document content.** A document contains text intended to steer the model	**M**	**H**	App Dev lead, Security review	Retrieved text fenced as data, not instructions. **The model has no tools and can take no actions.** No outbound network path from answering components except the gateway. Injection cases permanent in the golden set (§6.6)	Any injection case fails the golden set, or an anomalous answer traces to a passage containing instruction-like text
R-06	**The indexer identity is compromised.** `svc-askacme-indexer` can read every in-scope source	**L**	**H**	Marcus Reyes (CISO)	Read-only, no write anywhere. Scope enumerated per site, not tenant-wide. Credentials in CyberArk, rotated quarterly. Network-restricted to scoped endpoints, no general egress. Every read logged (§6.2)	Any access by this identity to a source outside its enumerated scope, or any authentication from an unexpected network location

ID	Risk	L	I	Owner	Mitigation	Trigger
R-07	**Eval gate not passed before the CAB deadline.** No evidence, so no RFC, so no release before the freeze	**M**	**H**	App Dev lead	Gate run in W7 with 4 days of float. Golden set authored in W5 so failures surface early. **[CTG]**	First full gate run fails on more than 20% of positive cases, or on **any** negative, honeypot or injection case
R-08	**Aggregation.** A user assembles something sensitive from multiple passages each of which they are permitted to read. Per-document authorization does not prevent this	**M**	**M**	Marcus Reyes (CISO)	Not solved in Phase 1, and stated as such. Narrow scope and a single audience per source limit exposure. Refusal and answer logs reviewed by Security weekly	Any Security review identifies an answer that reveals more than the sum of its cited sources
R-09	**Okta and Entra group membership diverge.** Assumption A6 fails, so the permission filter works from stale claims	**L**	**H**	Security lead	Group membership read from Entra, the same directory SharePoint's rules are written against, so no mapping layer exists to drift. `identity-resolver` **fails closed** — no claims means no passages. Behaviour on divergence to be defined with the identity team	Identity team confirms a divergence case, or any user reports access inconsistent with their SharePoint access
R-10	**Adoption failure.** The system works and nobody uses it, so no benefit and no measured demand figure	**M**	**H**	Birdie Roadman / PMO	Pilot cohort chosen for question volume. Baseline metrics taken pre-launch. Daily feedback during hypercare. Comms and training funded as WP-16, not treated as an afterthought	Fewer than 30% of the pilot cohort active by end of week 2 in production
R-11	**PartyPal breaks during containment.** Swapping the personal credential for a corporate one behind the gateway disrupts customer care	**M**	**M**	Birdie Roadman	Containment scheduled W4, well before peak season. Function documented before the change so failure is diagnosable. Change made outside business hours with the original credential retained until verified	Any customer care report of PartyPal failure within 48 hours of the credential change
R-12	**A provider model version change degrades answer quality** without ACME initiating anything	**M**	**M**	Quality owner	Golden set re-runs after every model version change, as a stated rule. Provider version pinned at the gateway where the provider supports it	Provider version-change notice, or golden set pass rate drops without a corresponding release
R-13	**Audit logs become an unmanaged confidential store.** Retrieved passages appear in logs, so the logs inherit the sensitivity of the corpus	**H**	**M**	Infra & Cloud lead	Logs classified Confidential with their own access controls and retention schedule (§6.1). Access limited to Security and the named owners	Any access to the log store by an identity outside the approved list
R-14	**Slip into the freeze.** Release attempted or landed	**L**	**H**	Dana Okafor	The 11 September go/no-go exists specifically to prevent this.	CAB of 24 September missed for any reason

ID	Risk	L	I	Owner	Mitigation	Trigger
	inside 1 Oct – 7 Nov			(sponsor)	**Squeezing a release into the freeze is not on the table under any circumstance**	
R-15	**Retrieval misses answers that exist.** Wording mismatch or a passage split across chunks	**M**	**L**	App Dev lead	Golden set positive cases measure it. Chunk size and passage count tuned against results. **Fails safe** — produces a non-answer, not a wrong answer	Positive case pass rate below the agreed threshold, with failures traced to retrieval rather than generation
R-16	**ArmoryOS file format changes** (Phase 3). Diagnosis requires Gene, at a weekly cadence	**L**	**M**	App Dev lead	Ingestion validates the file structure and alerts on mismatch rather than loading bad data. Gene's scheduled review captures the format in writing (ADR-003)	Nightly validation fails, or the file does not arrive
R-18	**EU data residency answered only for the model call.** If Phase 3 indexes EU customer records, the index and the audit logs hold EU personal data wherever they were deployed. Gateway routing does not address this	**M**	**H**	Ingrid Voss (DPO)	Recognised and carried openly rather than assumed solved (§5.8, ADR-002 §4.1). Phase 1 and 2 sources are US-held, so nothing before Phase 3 triggers it. Two costed options — a full EU stack, or EU personal data out of scope — decided at the Phase 3 gate with the DPO present. DPIA filed at project start	Phase 3 scoping begins, or any earlier source is found to contain EU personal data
R-19	**Routing becomes a control, not an optimisation** (if option 3a is chosen). A misrouted request breaches residency rather than slowing a response	**L**	**H**	Ingrid Voss (DPO)	Routing cases become permanent members of the release test set, at 100% with no exceptions. Only applies if option 3a is selected	Option 3a selected at the Phase 3 gate
R-17	**Cost overrun as usage grows.** Per-question cost scales with adoption	**L**	**L**	Priya Natarajan	Per-team ceilings at the gateway alert the named owner. Sensitivity analysis shows a 4× volume increase moves total cost 32% (§8.5). Model tiering available as a Phase 2 optimisation	Monthly model spend exceeds the $300 ceiling

11.2 The four risks that actually matter

Seventeen risks is a register. These four are what the programme is genuinely exposed to, and they are the ones to be ready to discuss:

R-01, the DPA. The only risk that can stop the programme outright, and the only one whose duration is entirely outside ACME's control. Everything else is manageable. This is why it is escalated in week 1 rather than tracked.

R-03, permission faults. The most likely overrun, on the widest-spread work package, resting on the assumption we are least confident about. Discovery is scheduled first precisely so this surfaces in week 2.

R-05, prompt injection. The risk that is not fully solvable by anyone today. The mitigations reduce the blast radius from "the model may take an action" to "the model may give a wrong answer" — which is a real reduction, not a solution.

R-13, the logs. Marked High likelihood because it is not really a risk of something going wrong; it is a certainty that needs managing. The moment the system runs, ACME has a new store of confidential content. Naming it is the mitigation.

R-18, EU residency beyond the model call. Included here because an earlier draft of this proposal got it wrong — it assumed gateway routing satisfied the requirement. It does not: the index and the logs hold data too. The correction is recorded rather than quietly amended, because the reasoning matters more than the tidiness.

11.3 Risks explicitly accepted without mitigation

Risk	Why accepted
Content up to 24 hours old, per source	The sources produce data on a schedule. Declared as a tolerance in §7.3 rather than engineered away
No availability outside business hours	No on-call rota exists and this programme does not fund one. Stated in §7.7
Aggregation (R-08) beyond narrow scope	No practical Phase 1 mitigation exists. Contained by scope, reviewed weekly, and stated
Copilot remains ungoverned by ACME's gateway	Out of scope (§2.7). A residual risk owned by the M365 team, not this programme

Naming a risk as accepted is not the same as ignoring it. Each of these is a decision with an owner.

Ends section 11.

Section 12 — Phase 1 Change Request

Drafted in ServiceNow RFC format for CAB, Thursday 24 September 2026, 10:00 ET. Chair: Tom Kowalczyk.

An RFC without a rollback plan is rejected. §12.6 is therefore the part of this section that matters, and it covers **data as well as code** — because rolling back software does not undo what a bad load wrote into the index.

12.1 Request header

Field	Value
Change type	**Normal**
Requested by	AI Enablement Program, PMO
Sponsor	Dana Okafor, CIO
Target window	Friday 25 September 2026, 18:00–22:00 ET
Freeze	**4 working days before the Spooky Freeze (1 Oct)** — stated explicitly so CAB can weigh it

Field	Value
proximity	
Implemented by	Infrastructure & Cloud (SOX: not by the authoring team)
Configuration items	`askacme-api`, `retrieval-svc`, `acl-verifier`, `prompt-assembler`, `web-ui`, `ai-gateway`, `index` (Postgres/pgvector), ingestion CronJob and connectors, `askacme-prod` namespace
Affected services	None existing. New service. No change to any current production system
Users affected	~70, Service Desk pilot cohort

12.2 Description

Deploy Phase 1 of AskACME to production: an internal knowledge assistant answering employee questions from four approved sources, enforcing authorization parity at retrieval, with all model traffic routed through the approved AI gateway.

Sources in scope: ServiceNow knowledge articles · SharePoint HR Policies · SharePoint Depot SOPs · SharePoint Sales enablement.

Not in scope: SAP ECC (migration moratorium) · Workday · Salesforce · ArmoryOS · SharePoint Corp Dev · SharePoint Legal/Claims (legal hold) · M365 Copilot.

12.3 Justification

Driver	Detail
Confidential material currently leaves ACME daily via personal consumer AI accounts, with no agreement, logging or retention control	Finding 2
A production dependency in customer care runs on one individual's personal credential	Finding 3 — contained under this programme in August
No AI governance layer exists: no gateway, no register, no evaluation practice, no cost attribution	Finding 6
~$400/month billing against an abandoned, unowned cloud resource	Finding 5 — retired under this programme in August

Consequence of not approving: the ungoverned position persists through peak season, and the next change window is after 7 November.

12.4 Risk assessment

Overall: Medium.

Factor	Assessment
Blast radius	Contained. New namespace with its own resource quota; network policy prevents egress from all components except the gateway. Cannot affect the storefront on the same cluster
Existing services touched	**None**

Factor	Assessment
Data written to source systems	**None.** All source access is read-only; the indexer identity holds no write permission anywhere
Payment path	Not approached. No interaction with the checkout or payment services
Reversibility	Full, in both code and data. See §12.6
Peak season proximity	4 working days before the freeze. Hypercare covers 28–30 September
Residual risks	R-05 (prompt injection), R-08 (aggregation), R-13 (log sensitivity) — all carried in section 11 with owners

12.5 Test evidence attached

Evidence	Detail
Golden-question set result, PREPROD	Positive cases at or above the agreed threshold; **negative, honeypot and injection cases at 100% with no exceptions**
Authorization parity demonstration	A Service Desk identity asking for pricing information receives no answer and no acknowledgement that a document exists. A sales identity asking the same question receives an answer with citations. Both logged
Refusal logging	Every refusal recorded with the asking identity and reason; sample reviewed and signed off by Security
Identity flow verification	Okta sign-in validated; Entra group resolution confirmed; fail-closed behaviour tested by making the directory unreachable
Load and latency	Latency at the 95th percentile within the §7.4 tolerances at expected pilot concurrency
Cost attribution	Per-team tagging verified against the gateway's own records
Rollback rehearsal	Performed in PREPROD on **18 September**, covering both code and data. Timings recorded in §12.6
Network policy verification	Egress attempted from a non-gateway pod and confirmed blocked

12.6 Rollback plan

Rollback covers two things, and they fail differently. Code rollback returns the software to a known-good release. Data rollback returns the index to a known-good state. **A bad load that wrote incorrect access labels is not fixed by rolling back code** — the software would be correct and the data would still be wrong. Both paths are therefore specified and both were rehearsed.

Part A — code rollback

Step	Action	Time
1	`kubectl rollout undo deployment/<name> -n askacme-prod` for each affected deployment	< 1 min
2	ReplicaSets swap back to the previous known-good revision; readiness probes gate traffic	~30 s
3	Confirm pod health and version	2 min
4	Re-run the golden set against the restored release	~10 min

Step	Action	Time
Total		**~15 min**

Part B — data rollback

Step	Action	Time
1	Disable the ingestion CronJob — `kubectl patch cronjob ... suspend=true` — to stop further writes	< 1 min
2	Restore the index from the pre-change snapshot taken immediately before the deployment window	~20 min
3	Verify passage count and label integrity against the snapshot manifest	10 min
4	Re-run the golden set, **including all honeypot cases**, against the restored index	~10 min
Total		**~40 min**

Part C — the fastest safe action

If authorization parity is in doubt for any reason, the first action is **not** a rollback:

Step	Action	Time
1	Scale `retrieval-svc` to zero replicas	< 1 min
2	The service returns no passages, so no answers are produced. **The system fails to answering nothing**	immediate
3	Then diagnose without time pressure, and roll back code or data as needed	—

This is the important point about the design. Because enforcement sits at retrieval, removing retrieval removes the ability to disclose anything. There is no path by which the model can answer from company content without the retrieval service. A one-minute action makes disclosure impossible while the cause is investigated.

Rollback triggers

Any one of these, and rollback begins without further discussion:

Trigger	Response
Any honeypot or negative case fails in production	Part C immediately, then B, then A
Any user reports content they should not be able to access	Part C immediately, then investigate
Availability below the §7.2 tolerance for more than 30 minutes	Part A
Latency at p95 exceeding double the §7.4 tolerance for more than 30 minutes	Part A
Model spend exceeding 3× the daily run-rate implied by the ceiling	Suspend gateway credentials, then investigate
Ingestion writes labels that fail integrity validation	Part B

Backout decision authority

Situation	Who decides
Authorization failure of any kind	**Security duty officer, unilaterally.** No approval required, no meeting

Situation	Who decides
Availability or latency breach	Infra & Cloud on-call
Cost anomaly	Data & Analytics on-call, with Priya Natarajan informed
Anything ambiguous	Programme sponsor

Deliberately asymmetric. Stopping the system requires one person's judgement. Starting it again requires a decision and a passing eval run.

Backout window

Rollback remains available for the full hypercare period, 25–30 September. The pre-change index snapshot is retained for 30 days. **During the freeze, only an Emergency change may be raised**, using the same rollback procedure under the Emergency path — which is why it was rehearsed on 18 September rather than documented and hoped for.

12.7 Communications plan

Audience	When	Message
Service Desk pilot cohort	22 Sep	What it does, what it deliberately will not do (§7.7), how to report a problem
Service Desk management	22 Sep	Baseline metrics being compared, feedback sessions daily during hypercare
Security	25 Sep	Refusal log location; daily review during hypercare
Priya Natarajan	25 Sep	Cost dashboard live, per-team attribution active
All staff	**Not yet**	No enterprise announcement during a 70-person pilot. Deliberate — see below

No company-wide announcement at Phase 1. A 70-person pilot announced to 7,400 people produces demand that cannot be served, and expectations that will be missed. The CEO's board headline is available at the Phase 1 gate review with measured results behind it, which is a better headline than an announcement.

12.8 Post-implementation review

Item	When
Hypercare daily review	28–30 Sep
Golden set run	Daily during hypercare, then weekly
Refusal log review by Security	Daily during hypercare, then weekly
PIR to CAB	First CAB after the freeze, Thursday 12 November
Phase 1 gate review — including measured assumption A7	From 10 November

---

12.9 Approvals required

Approver	For
Tom Kowalczyk, CAB chair	The change itself
Marcus Reyes, CISO	Authorization parity evidence and the refusal log
Ingrid Voss, DPO	DPIA outcome
Priya Natarajan, VP Data	Gateway routing and cost attribution
Dana Okafor, CIO	Programme sponsor sign-off

Ends section 12.

Section 13 — Assumption Log

Every assumption in this proposal, with what it rests on and how it would be closed. Maturity: **ROM** (rough order of magnitude, ±50%) · **refined** · **validated**.

The purpose of this log is that no number in this document is unattributable. If a figure is questioned, its origin is stated here rather than reconstructed on the spot.

Needs and scope

ID	Assumption	Basis	Maturity	How to close
A1	Poor findability caused the shadow-AI workarounds	Both facts are canon; the causal link is our inference	ROM	Interview the sales team and Service Desk
A2	The specific permission faults in SharePoint are unknown	Dossier says “inconsistent” and “sprawl”; names no fault type	ROM	Interview Security on the Copilot review findings, then W2 discovery
A3	Permission remediation cost scales roughly per site	Inferred from the Copilot pilot’s five-month duration	ROM	Measure across the four Phase 1 sites, then re-estimate Phase 2
A4	Nothing critical depends on the abandoned Azure workspace	Described as abandoned; not confirmed	ROM	Confirm with Data Science before retirement
A5	Contract drafts pasted into consumer AI include EU personal data	Inferred from the existence of EU supplier and staff contracts	ROM	Confirm with Legal and the DPO

Identity and architecture

ID	Assumption	Basis	Maturity	How to close
A6	Okta and Entra group membership are consistent	Both derive from Active Directory; not verified	ROM	Confirm with the identity team; define behaviour on divergence
A8	Five passages per question is sufficient for answer quality	Starting value	ROM	Tune against the golden set in W7
A9	~500-token passages with 15% overlap is an appropriate split	Starting value	ROM	Tune against the golden set in W7
A10	A 5-minute cache on group membership is an acceptable staleness window	Design judgement, balancing directory load against currency	ROM	Review with Security; shorten if challenged
A11	The Phase 1 corpus is roughly 3,000 documents / 12,000 passages	Estimated from four sources	ROM	Measured during W2 discovery

Cost and demand

ID	Assumption	Basis	Maturity	How to close

ID	Assumption	Basis	Maturity	How to close
A7	**8 questions per active user per working day**	Unmeasured. **The single most load-bearing assumption in this proposal**	**ROM**	**Measured during Phase 1 and through the freeze. Primary reason the Service Desk is the pilot cohort.** Sensitivity in §8.5 shows a 4× error moves total cost by 9%
A12	Token rates of $3.00 input / $15.00 output per million	**Placeholder planning rates, not prices**	ROM	Replaced by the contracted rate once the enterprise agreement clears
A13	Adoption ramp of 40% / 60% / 75% across a phase's first three months	Planning judgement	ROM	Measured during Phase 1
A14	Blended internal staff cost of $75/hour fully loaded	Planning rate	ROM	Confirm with ACME Finance
A15	20% overhead on model spend for retries, failures and eval runs	Allowance	ROM	Logged at the gateway from day one
A16	0.3 FTE is sufficient to run and operate Phase 1	Planning judgement	ROM	Reviewed at the Phase 1 gate

Schedule

ID	Assumption	Basis	Maturity	How to close
A17	Firewall requests clear in 2–3 weeks if correctly formed	**[C]** — stated in canon	refined	Submitted W1; tracked as R-02
A18	Site owners are available in weeks 2–3	Not confirmed	ROM	Meetings booked W1; carried as R-04
A19	The DPA clears in time for a 24 September CAB	**Not within ACME's control**	ROM	Escalated W1. Assessed at the 11 September go/no-go. Carried as R-01
A20	An 85% pass threshold on positive test cases is appropriate	Proposed, not agreed	ROM	Agreed with Security and the sponsor before Phase 1 release
A21	No Phase 1 or Phase 2 source contains EU personal data	Inferred from the sources being US-held — HR policies, help articles, depot procedures, US pricing	ROM	Confirm with the DPO before Phase 1 load. **If false, the residency decision moves forward from Phase 3**

The four to volunteer before being asked

A7 — questions per user per day. Everything volumetric rests on it, it is a guess, and the sensitivity analysis shows the proposal survives being wrong about it.

A2 — we do not know what is actually wrong with SharePoint's permissions. This is why remediation is a funded work package with a 15-to-45-day spread rather than an assumption.

A12 — the token rates are placeholders, not prices. The contracted rate is unknown until the agreement clears.

A19 — the DPA timing is outside ACME's control. It is the only risk that can stop the programme, which is why there is a named go/no-go date rather than hope.

Ends section 13.

Appendix A — Persona detail

Name	Role	Groups	Disposition
Wiley E. Cunningham III	CEO, founder's grandson	exec	Board asked "what's our AI story?" Wants headlines, not mechanics
Dana Okafor	CIO, **programme sponsor**	exec, it-eng	Pragmatic; burned by the S/4 migration; wants governed wins
Marcus Reyes	CISO	exec, security	Skeptic. Owns Zscaler, CrowdStrike, Splunk. "No data leaves without a DPA"
Priya Natarajan	VP Data & Analytics	it-eng, data	Owns Snowflake. Wants a central AI gateway and cost attribution, or vetoes
Birdie Roadman	VP Events Operations	events-ops	Impatient business owner. Her team built PartyPal and depends on it
Tom Kowalczyk	Change Manager, CAB chair	it-eng	Runs CAB Thursdays 10:00 ET. Rejects RFCs without rollback plans
Ingrid Voss	Data Protection Officer, Łódź	legal, dpo	GDPR authority. EU personal data stays in the EU. Guards claims files fiercely
Sal Marchetti	Enterprise Sales Director	sales	Pastes contract drafts into personal ChatGPT. A DLP finding waiting to happen
"Mo" Alvarez	Depot Manager, Armory #3	depot-ops	ArmoryOS power user. Distrusts anything that isn't a green screen
Gene Podowski	Contractor, semi-retired	it-legacy	Only human who understands ArmoryOS RPG. Invoices hourly. Replies weekly

---

Appendix B — Classified data-source inventory

Classification tiers: **Public → Internal → Confidential → Restricted**

Source	Content	Tier	Authorised audience	Access mechanism and constraints	Phase
SharePoint — HR Policies	Handbook, PTO, benefits	Internal	All employees	Graph API, read-only, scoped	1
ServiceNow — KB	Knowledge articles	Internal	All employees	REST API, scoped service account	1
SharePoint — Depot SOPs	Assembly, refurb, safety	Internal	depot-ops, events-ops	Graph API; group-scoped labels	1
SharePoint — Sales enablement	Pricing sheets, discount matrices	**Confidential**	sales, exec	Graph API; **live group re-check before use**	1

Source	Content	Tier	Authorised audience	Access mechanism and constraints	Phase
SharePoint — Engineering wiki	Runbooks, architecture docs	Internal	it-eng	Graph API; group-scoped labels	2
SharePoint — Product Safety	Test reports, failure analyses	**Confidential**	quality, legal, exec	Graph API; live re-check before use	2
SharePoint — Corp Dev	"Project Slingshot" memo	**Restricted**	exec only	Graph API; live re-check; **honeypot**	2
Salesforce	Accounts, contacts, opportunities, cases	**Confidential**	sales, service	REST API; **must honour record-level sharing**	3
ArmoryOS	Rental inventory, refurb logs	Internal	depot-ops	**Nightly SFTP drop only.** Live query technically available via a legacy endpoint but **declined** — see ADR-003	3
ServiceNow — tickets	Ticket histories	Internal	it-eng	REST API, scoped	3
SAP ECC	Financials, vendor master, BOMs	Confidential	finance, ops	**Excluded.** Moratorium. Snowflake is the sanctioned route if ever needed	—
Workday	Compensation, performance	**Restricted**	HR + self	**Excluded.** No identified need	—
SharePoint — Legal / Claims	Trebuchet incident file	**Restricted**	legal only	**Excluded indefinitely** — legal hold, active litigation. **Honeypot; tested but not indexed**	—

Appendix C — The Twelve Questions: Self-Audit

A note on what this is. The course refers to "The Twelve Questions" as the spine of the review. That list was not issued to us in advance. What follows is **our reconstruction** — twelve questions derived from the five non-negotiables, the stakeholder veto map, and the emphasis of the course material. Each is answered, pointed to a section, or carried on the risk register.

If the actual list differs, this audit should be re-run against it. The purpose is not to guess the questions correctly; it is to demonstrate that no part of this proposal is unaccounted for.

Q1 · Where is authorization enforced, and how do you prove it works?

Answered. At search time, as the single stated enforcement point (**ADR-001**). Loading labels each passage with the access rules it inherited from the source; the search filters on the asker's current group membership. Confidential and Restricted material is re-verified live against the source before use.

Proof: the release test set includes honeypot cases at 100% with no exceptions (**§7.6**). A Service Desk identity asking for pricing receives nothing while a sales identity receives an answer, and both are logged (**§12.5**). Every refusal is recorded with the asking identity and reason.

Pointer: ADR-001 · §5.2 hop 08 · §6.8 · §7.6 · §12.5

Q2 · Who or what reads your sources, and how is it contained?

Answered, and volunteered rather than waited for. `svc-askacme-indexer` — a non-human identity that reads every in-scope source including Confidential material, and exists from the moment loading begins. It is the most dangerous thing this programme creates.

Containment: read-only with no write permission anywhere; scope enumerated per site rather than tenant-wide; credentials in CyberArk, rotated quarterly; network-restricted to its scoped endpoints with no general egress; cannot read the index it writes to; every read logged.

Pointer: §6.2 · R-06

Q3 · What happens when someone's permissions change?

Answered. Group membership is read live at question time, so a change takes effect on the person's next question rather than at the next index rebuild. This is the reason enforcement sits at search rather than at loading.

The asymmetry is deliberate: content is as fresh as the last load, up to 24 hours; permissions are current. Stale content is an inconvenience; stale permissions are a leak.

Residual: a 5-minute cache on group claims (**A10**) is the one staleness window, and it is stated rather than hidden.

Pointer: ADR-001 · §6.2 · §7.3 · A10

Q4 · Where does ACME's data go, and what leaves the company?

Answered. §5.4 tabulates every boundary crossing with its control and its residual risk. What leaves ACME's network is the assembled prompt — instruction text, retrieved passages, and the question — passing through the gateway and then the egress proxy.

Nothing leaves before the DPA is signed. Development runs on synthetic content precisely so this constraint is not quietly breached during the build.

Residual: redaction catches structured patterns reliably and prose poorly. It is a safety net, not a control. The control is that unauthorised content is never retrieved.

Pointer: §5.4 · §6.7 · R-01 · R-13

Q5 · How does EU personal data stay in the EU?

Answered, and the easy wrong answer is named. Gateway region routing sends EU-origin model calls to an EU endpoint — **but that covers the model call only.** If Phase 3 indexes EU customer records, EU personal data also rests in the index and in the audit logs, both of which sit wherever they were deployed.

So two options genuinely satisfy the requirement, and the choice is taken at the Phase 3 gate with the DPO present: a full second stack in an EU region with its own index and logs (roughly doubling the infrastructure footprint, and making routing correctness a control rather than an optimisation), or EU personal data kept out of scope.

Timing: Phase 1 and 2 sources are US-held, so nothing before Phase 3 triggers this — carried as assumption **A21**, to be confirmed with the DPO before the first load. **The DPIA is filed at project start regardless**, because it has lead time and it is the instrument through which this decision gets tested.

Recorded as a correction. An earlier draft of this proposal stated that routing alone satisfied residency. It does not, and the correction is documented in ADR-002 §4.1 rather than quietly amended.

Pointer: ADR-002 §4.1 · §5.8 · R-18 · R-19 · A21

Q6 · What is your rollback, and does it cover data?

Answered — and data is the part most rollback plans miss. Rolling back code does not undo a bad load that wrote incorrect access labels into the index. So there are three parts:

1. **Fastest safe action:** scale the retrieval service to zero. Under a minute, and disclosure becomes impossible while the cause is diagnosed. This works *because* enforcement sits at retrieval.
2. **Code:** `kubectl rollout undo`, ReplicaSets swap back, then re-run the test set. ~15 minutes.
3. **Data:** suspend ingestion, restore the index from the pre-change snapshot, verify label integrity, re-run all honeypot cases. ~40 minutes.

Rehearsed on 18 September, not merely documented. Stopping requires one person's judgement; restarting requires a decision and a passing test run.

Pointer: §12.6

Q7 · What does one question cost, and how do you know?

Answered, with every input traceable. Model cost per question is approximately **$0.015**; all-in cost including infrastructure and staff is approximately **$0.17**. Every input traces to the measurement table at **§8.1**, which states its value, its maturity label, and how it becomes a measured figure.

The finding worth stating: across the year-one total of about $246,300 — Phase 1 build plus running cost across all phases — **people are roughly 87% and the model is about 4%** (§8.5). Within running cost alone, staff is 65% and the model 11%. A cost conversation that starts with token prices is looking in the wrong place.

The honest caveats: token rates are **placeholders** until the contracted rate is known (**A12**), and questions per user per day is a pure assumption (**A7**) — though sensitivity analysis shows a fourfold error moves total cost by 9%.

Pointer: §8.1 · §8.2 · §8.5 · A7 · A12

Q8 · What happens when the release test set fails?

Answered. The release does not ship. The gate fails closed, with no override and no discussion. Negative, honeypot and injection cases must pass at 100% with no exceptions; positive cases carry a threshold, proposed at 85% and to be agreed with Security before Phase 1 release (**A20**).

Why the thresholds differ: a missed answer fails safe, because the user escalates as they do today. A leaked document does not fail safe. The asymmetry in the thresholds reflects the asymmetry in the consequences.

The set also re-runs after any provider model version change, because a version change is a change to the system whether or not ACME initiated it.

Pointer: §7.6 · ADR-004 · §12.5

Q9 · What is on your critical path, and what has zero float?

Answered. DPA clearance → gateway configured with production credentials → test gate passed → CAB Thursday 24 September → production before 1 October.

Zero float: DPA clearance, which is outside ACME's control, and the 24 September CAB, because the next Thursday falls inside the freeze.

Near-critical: the firewall request has roughly one week of float against a 2–3 week queue — a malformed CIDR consumes it entirely, which is why the request format is specified precisely and submitted on day one.

The branch is named in advance: a go/no-go on **11 September**. If the DPA has not cleared, Phase 1 goes live from 9 November. Releasing inside the freeze is not on the table.

Pointer: §10.4 · §10.5 · R-01 · R-02

Q10 · What did you deliberately not promise?

Answered. Seven things, listed at **§7.7**: availability outside business hours, live rental inventory, booking confirmation, that every answerable question will be answered, customer-facing use, answers from SAP, and that this work unblocks Copilot.

Why this list exists at all. The riskiest targets are the unwritten ones — ACME already has two examples in the checkout service's implicit expectation of perfection and PartyPal's undocumented dependency. An unmeasured expectation is still an expectation; it simply cannot be engineered.

Pointer: §7.7 · §2.7

Q11 · What is the weakest part of this proposal?

Answered, in order.

Prompt injection (R-05). Retrieved documents are content we do not control. The mitigations reduce the consequence to a wrong answer rather than an action, but the problem is not fully solved by anyone today.

We do not know what is wrong with SharePoint's permissions (A2). Only that Security found the tenant-wide picture serious enough to block Copilot for five months. Hence a work package with a 15-to-45-day spread rather than an assumption, and discovery scheduled as the first activity.

Aggregation (R-08). Per-document authorization does not prevent someone assembling something sensitive from several passages they are each permitted to read. No practical Phase 1 mitigation exists. Contained by narrow scope, reviewed weekly by Security, and stated.

The audit logs (R-13). Marked high likelihood because it is a certainty rather than a risk: the moment this runs, ACME has a new store of confidential content. Naming it is the mitigation.

Pointer: R-05 · R-08 · R-13 · A2 · §6.6

Q12 · What happens to PartyPal?

Answered — and a decision here is mandatory. Contain within 30 days, replace in Phase 3, retire on a date Birdie Roadman signs off (**ADR-005**).

Containment removes the acute risk inside a month: a named owner of record, the personal credential replaced with a corporate one held by the gateway, logging switched on, and a written description of what it does and who depends on it. Replacement waits for Phase 3 because booking questions need rental data.

Not switched off now, because customer care depends on it and there is no alternative — shutting it down before peak season would be a self-inflicted outage. **Not adopted as-is**, because that would bless the exact pattern this programme exists to end.

One rule, applied twice: the abandoned Azure workspace is handled identically — register, find the owner, contain, retire on an agreed date with sign-off.

Pointer: ADR-005 · §2.2 F3 · §2.2 F5 · §10.3 M4

Coverage check

Course material	Where it appears in this proposal
Company dossier — personas, systems, data tiers, honeypots	§2 throughout, Appendices A and B
Decision doctrine: drivers → decision → consequences	§4 and all five decision records
Networking: hops, five-tuple, firewall request format, gateway taxonomy	§5.2, §6.5, §6.7
Streaming versus idle timeouts, buffering	§6.5
Egress proxy, TLS inspection, default-deny to model endpoints	§5.4, §6.7, §10.1
Kubernetes: namespace, quota, network policy, RBAC, probes, PDB, rollout undo	§6.4, §12.6
Topology: zones absorbed, regions are architecture, spread constraints	§5.8, ADR-002
SLI / SLO / SLA, error budgets, engineering to tolerances	§7.1, §7.2
Unwritten SLOs — the checkout service, PartyPal	§7.7
Cost behaviour, unit cost of one query, demand model, sensitivity	§8
Total cost of ownership, and delivery approach with its drivers	§8.8, §8.9
Three-point estimating, PERT, visible contingency	§9.3, §9.4
Critical path, immovable objects, external queues	§10
Eval gates as a release condition	§7.6, §12.5

Course material	Where it appears in this proposal
Authorization parity, honeypots, enforcement point choice	ADR-001, §5.7, §7.6
The trap pattern and its mitigation on the same sheet	§5.5, §6.6
The ladder — hosting options	ADR-002 *(deck not available to us; our reconstruction of the three rungs)*

Known gaps in our source material, stated rather than hidden: the Twelve Questions list, the Day 1 needs-analysis method deck, the retrieval/RAG deck, and "the ladder" deck were not available. Where the course's own vocabulary would have been preferable, ours has been used and labelled.

Ends Appendix C.